

CYBER SECURITY OPERATIONS

PHASE 02

Aggregation & Normalisation

DETAILED STUDY NOTES

Prerequisites: Basic understanding of security logs · JSON · CSV formats

Feeds into → Phase 03 (SOC & SIEM) and Phase 05 (Workflow Automation)

Overview & Motivation

Phase 02 — **Aggregation & Normalisation** — consolidates and standardises diverse security data from multiple sources so that every downstream process receives consistent, queryable data. Without this phase, analysts comparing events from firewalls, Windows endpoints, IDS sensors and VPN gateways would face incompatible timestamps, mismatched severity scales, and unrelated field names.

Phase 01	Collection	Raw logs gathered from all sources
Phase 02	Aggregation & Normalisation	THIS DOCUMENT — standardise, correlate, enrich
Phase 03	SOC & SIEM	Human analysis + rule-based detection
Phase 05	Workflow Automation	Automated playbook execution

Two Core Activities in Phase 02

Setting Up Actionable Insights	Configure detection rules, thresholds and correlation logic that turn normalised security data into meaningful intelligence driving immediate action. Define what counts as suspicious behaviour, establish baselines, create risk scores, and set automated alert conditions — all aimed at reducing false positives while catching genuine threats.
Continuous Improvement Pipeline	Regularly test accuracy of data conversion, validate that correlation rules remain effective, measure processing speeds and alert accuracy, and benchmark against operational requirements. Continuous testing surfaces areas for improvement and maintains reliability of monitoring capabilities.

PART 1 — Data Normalisation

Normalisation transforms raw, source-specific log data into a single consistent schema. Each source uses its own timestamp format, severity naming, and field set. Normalisation maps everything to a universal template before any analysis begins.

The 6-Step Normalisation Process

1

Identify Source Log Formats

- Review each log source's structure — CSV, JSON, plain text, custom formats
- Document the fields available in each source (name, type, optionality)
- Note unique characteristics such as delimiters, encodings, or embedded metadata

2

Create a Field Mapping Strategy

- Map every source field to the normalised template field
- Classify fields as required vs optional
- Plan how source-specific fields are stored in `additional_details`
- Document any fields needing special transformation logic

3

Standardise Common Fields

- Timestamps → ISO 8601 (e.g., 2024-02-02T10:15:23Z)
- Severity → unified scale: info | low | medium | high | critical
- Event types → lowercase_with_underscores convention
- IP addresses and ports → consistent string format

4

Handle Data Type Conversions

- Numbers → appropriate string representations
- Booleans → YES/NO or TRUE/FALSE (consistently)
- Arrays → comma-separated strings
- Derived fields → calculate (e.g., `bytes_transferred = bytes_in + bytes_out`)

5

Implement Normalisation Rules

- Apply field mappings to each log type programmatically
- Handle missing or null values gracefully (fill with empty string, not null)
- Preserve original raw log data in `additional_details`
- Apply any source-specific transformations (e.g., Unix epoch → ISO 8601)

6

Validate Normalised Output

- Verify all required fields are present
- Check data type consistency across all events
- Validate timestamp formats and timezone standardisation
- Ensure IP address and port formatting is correct
- Confirm severity level mapping accuracy

Normalised Event Template — Field Reference

Field	Type	Required ?	Notes
normalised_timestamp	ISO 8601 string	✓ YES	Always UTC
event_type	string	✓ YES	lowercase_underscores
source_type	string	✓ YES	windows_security, firewall, ids, vpn...
severity	string	✓ YES	info/low/medium/high/critical
source_ip	string	optional	Empty string if unavailable
source_port	string	optional	
destination_ip	string	optional	
destination_port	string	optional	
protocol	string	optional	TCP, UDP, etc.
action	string	optional	BLOCK, ALLOW, DETECT, CONNECT...
username	string	optional	
system_name	string	optional	
event_id	string	optional	Source-specific ID
signature	string	optional	IDS/IPS signature names
bytes_transferred	string	optional	Derived from in+out
raw_message	string	optional	Original log message
additional_details	JSON object	optional	All source-specific extras

Source-Specific Normalisation Examples

Windows Event Log (CSV input)

- Timestamp: '2024-02-02 10:15:23' → ISO 8601: '2024-02-02T10:15:23Z'
- EventID 4625 → event_type: 'authentication_failure'
- EventID 4624 → event_type: 'authentication_success'
- Level 2 → severity: 'medium' (scale: 0=info, 1=low, 2=med, 3=high, 4+=critical)

- 4625 authentication_failure
- 4624 authentication_success
- 4688 process_execution
- 5140 network_access

Firewall Log (JSON input)

- Unix epoch '1706866523' → new Date(ts*1000).toISOString() → ISO 8601

- Calculate `bytes_transferred = bytes_sent + bytes_received`
- Severity strings pass through unchanged (low/medium/high/critical)
- Store `bytes_sent` and `bytes_received` in `additional_details`
- Store `rule_id` as `event_id`

IDS Alert (plain text input)

- Timestamp already near-ISO 8601 — strip timezone offset, normalise to UTC
- Parse source IP from the alert message using regex
- Priority: 'High' → severity: 'high' (title-case to lowercase mapping)
- action → 'DETECT' (IDS detects, does not block)
- Store `alert_type` in `additional_details`

VPN Log (pipe-delimited custom format)

- Split on '|' separator, then split key=value pairs
- 'CONNECT' → 'vpn_connection', 'DISCONNECT' → 'vpn_disconnection', 'FAILED' → 'vpn_failure'
- `bytes_transferred = bytes_in + bytes_out`
- Timestamp '2024-02-02 10:15:23' → ISO 8601
- Store `pool`, `duration`, `2fa`, `bytes_in`, `bytes_out` in `additional_details`

PART 2 — Data Aggregation

Aggregation takes the already-normalised events from all sources and merges them into a single unified dataset. Because normalisation has already harmonised field names and formats, aggregation can focus entirely on combining, correlating and enriching data to produce actionable security intelligence.

The 8-Step Aggregation Process

1

Collect Normalised Events

- Gather normalised events from all security sources: Windows, Firewall, IDS, VPN, etc.
- Validate data integrity — confirm no information was lost during normalisation
- All events now share consistent field names, types and structures

2

Create Combined Chronological Timeline

- Merge all events into a single list and sort by normalised_timestamp
- Assign unique sequence IDs to each event (or group of simultaneous events)
- Time synchronisation is critical — small discrepancies distort event ordering
- Account for simultaneous events from multiple systems

3

Group Related Events by Common Attributes

- Group by source IP, username, event type, system identifier
- Reveals patterns invisible in the raw timeline (e.g., repeated failures from one IP)
- Consider which attributes are most relevant for your threat model
- Example: grouping by source_ip exposes multi-vector attack chains

4

Create Event Correlations

- Identify cause-and-effect relationships between events across sources
- A failed VPN + local auth failure + IDS alert from same IP = likely breach attempt
- Correlation rules must balance sensitivity (catch threats) vs specificity (avoid false positives)
- Tune rules based on the organisation's specific environment and threat landscape

5

Generate Summary Statistics

- Calculate event frequencies, failure rates, and activity patterns
- Totals by event type, source, severity and time period
- Establish baselines — normal failure rate makes unusual spikes visible
- Statistics feed security metrics and KPIs

6

Build Incident Timelines

- For each identified incident, construct a phase-by-phase timeline
- Phases: initial_access_attempt → lateral_movement → attack_attempt → attack_blocked
- Include all relevant events from all security systems
- Essential for incident response, forensics and lessons-learned

7

Document Attack Patterns

- From correlated events, extract reusable pattern signatures
- Each pattern: name, stage sequence, indicators (source IP, username, timeframe)
- Documented patterns improve future detection rules and staff training
- Supports proactive threat hunting and incident prediction

8

Generate Comprehensive Reports

- Executive summary: key findings, critical incidents, pattern analysis
- Detailed timeline: chronological events, cross-system correlations, attack progression
- Statistical analysis: event frequency, severity distribution, auth success/failure rates
- Recommendations: identified gaps, suggested improvements, monitoring enhancements

Worked Example — Authentication Bypass Attempt

The following example traces a single attack attempt through all 8 aggregation steps using events from four sources recorded at 2024-02-02T10:15:23Z from IP 192.168.1.100.

Step 3 — Grouped by IP: 192.168.1.100

- vpn → vpn_failure
- windows_security → authentication_failure
- ids → security_alert (SQL_INJECTION_ATTEMPT)

Step 4 — Correlation: CORR-001

- Trigger: vpn_failure from 192.168.1.100
- Related: windows auth failure (same_ip_and_time)
- Related: IDS SQL injection alert (subsequent_attack_attempt)

Step 5 — Statistics (16 total events)

- 70% authentication failure rate (7 of 10 attempts)
- Top IP: 192.168.1.100 — 8 events, 3 high-severity
- By source: VPN 6, Windows 8, IDS 4, Firewall 4

Step 6 — Incident INC-001 Phases

- initial_access_attempt: failed VPN auth for admin
- lateral_movement_attempt: failed local Windows auth
- attack_attempt: SQL injection detected by IDS
- attack_blocked: connection blocked by firewall

Step 7 — Pattern PTN-001: Authentication Bypass Attempt

- Stage 1: multiple VPN failures
- Stage 2: local authentication attempts
- Stage 3: web application attack (SQL injection)
- Indicators: source_ip + username + within_1_minute timeframe

Common Challenges Reference

Both normalisation and aggregation are affected by a range of recurring challenges. Understanding these in advance helps teams design robust pipelines and plan for edge cases.

Data Quality Challenges	Volume & Performance Challenges
• Inconsistent timestamp formats across sources • Missing or null values in critical fields • Duplicate events from different sources • Varying levels of detail between sources • Data corruption or incomplete log entries • Inconsistent character encodings	• Large data volumes impacting processing speed • Resource constraints during aggregation peaks • Real-time processing requirements • Storage limitations for historical data • Network bandwidth for distributed systems • Query performance on aggregated datasets
Correlation Challenges	Standardisation Challenges
• Establishing reliable event relationships • Identifying and removing false correlations • Time synchronisation between distributed systems • Distinguishing causation from correlation • Complex event chains spanning multiple sources • Gaps in event sequences	• Different naming conventions across sources • Varying severity level scales (1-10 vs low/high) • Inconsistent IP address formats (IPv4/IPv6) • Multiple username formats (domain\user, UPN, etc.) • Different event categorisation methods • Source-specific field meanings
Technical Challenges	Operational Challenges
• Different log formats: CSV, JSON, XML, syslog, custom • Multiple data storage locations • Network connectivity issues to log sources • System time synchronisation (NTP drift) • API rate limits and access restrictions • Tool compatibility issues	• Maintaining and updating aggregation rules • Keeping correlation logic current • Managing false positive volumes • Training staff on new tooling • Documenting processes and decisions • Handling source system changes

Good Practice Guidance

Establish Common Normalisation Factors

Timestamp Standardisation

- Always convert to ISO 8601
- Standardise to UTC timezone
- Handle both Unix epoch and human-readable input formats

Severity Level Mapping

- Use consistent scale: info → low → medium → high → critical
- Map all input formats to these standard levels
- Document every custom mapping rule for auditability

Event Type Classification

- Lowercase with underscores only (e.g., authentication_failure)
- Be consistent — similar events must share event_type values
- Group related events under common parent types

IP Address & Port Handling

- Validate IP address formats before storing
- Convert all ports to strings for consistency
- Handle missing values with empty string, not null/None

Additional Details

- Store all source-specific fields in additional_details
- Preserve original values even when normalising
- Document every data transformation applied

Establish Field Mapping Rules

Required Fields

- normalised_timestamp, event_type, source_type, severity
- These four must always be present — reject events missing them

Optional Fields

- Fill with empty string if not available — never omit from template
- Use additional_details for anything outside the standard schema

Data Type Standardisation

- Timestamps: always ISO 8601 strings
- Numbers: convert to strings
- Booleans: YES/NO or TRUE/FALSE — pick one and stick to it

- Arrays: convert to comma-separated strings

Validate Normalisation Output

Validation Checklist

- Check timestamp format consistency across all events
- Verify severity level mapping is correct
- Ensure all template fields are present in every event
- Validate IP address formats
- Check all required fields are populated
- Verify data type consistency

Data Handling & Documentation

What to Preserve & Document

- Always preserve the original raw log data
- Document all field mappings in a central reference
- Use standardised formats (ISO 8601 for timestamps everywhere)
- Include source-specific metadata in additional_details
- Maintain clear audit trails for all transformations
- Follow data privacy best practices (PII masking where required)

Indicative Open-Source Tools

Security Onion

All-in-one security monitoring platform

- Complete VM images available — minimal setup required
- Bundles the ELK stack, Zeek, Suricata, and more
- Excellent documentation and training materials
- Ideal for learning multiple SOC disciplines simultaneously
- Community-supported with active development

ELK Stack (Elasticsearch, Logstash, Kibana)

Industry-standard log management and analysis toolchain

- Available as a pre-configured VM
- Logstash handles normalisation (parsing + transformation)
- Elasticsearch provides fast full-text search on aggregated data
- Kibana delivers dashboards and visualisations
- Large community, extensive documentation, manageable resources

Graylog

Dedicated log management with strong normalisation

- Dedicated VM appliance — easy deployment
- User-friendly web interface aids visualisation of the pipeline
- Extractors and pipeline processors provide excellent normalisation
- Can run on minimal hardware (4 GB RAM minimum)
- All-in-one: input, normalisation, storage, and viewing

Logstash (standalone)

Normalisation-focused pipeline tool

- Part of ELK but usable standalone
- YAML-based configuration — low barrier to entry
- Robust parsing and transformation capabilities

- Can run with 2–4 GB RAM

- Great for learning data pipeline concepts in isolation

Quick Reference Summary Card

Concept	Key Point
Normalisation goal	One universal schema for all source events
Aggregation goal	Correlated, enriched, actionable intelligence
Timestamp format	ISO 8601 · UTC · e.g. 2024-02-02T10:15:23Z
Severity scale	info → low → medium → high → critical
Event type format	lowercase_with_underscores
Missing fields	Empty string — never omit from template
Original data	Always preserved in additional_details
Required fields	normalised_timestamp, event_type, source_type, severity
Correlation output	CORR-ID linking trigger + related events
Incident output	INC-ID with phase timeline + severity + status
Attack pattern output	PTN-ID with stage sequence + indicators
Report sections	Executive summary · Timeline · Stats · Recommendations
Top tools	Security Onion · ELK Stack · Graylog · Logstash

Phase 02 — Aggregation & Normalisation · Cyber Security Operations Process Cycle · These notes combine both the Normalisation Insights and Aggregation Insights documents.

Log Analysis Workflow

A typical log analysis workflow follows five sequential stages. This workflow provides context for where Phase 02 (Aggregation & Normalisation) sits within the broader security operations pipeline. Each stage depends on the output of the previous one.

1

Collection

Gather raw logs from all security sources — firewalls, Windows endpoints, IDS sensors, VPN gateways, access control systems. Establish reliable collection methods ensuring complete data capture with no gaps.

2

Parsing

Read and interpret the raw log structure. Identify delimiters, field positions, encodings and formats (CSV, JSON, XML, syslog, custom). Extract individual fields from raw strings before any transformation.

3

Normalisation

Standardise parsed data into a single universal schema. Convert timestamps to ISO 8601, map severity levels to a unified scale, enforce consistent naming conventions. This is Phase 02 (Normalisation) from your study notes.

■ PHASE 02

4

Analysis

Correlate, aggregate and enrich normalised events. Group by common attributes, identify event relationships, generate statistics, build incident timelines and document attack patterns. This is Phase 02 (Aggregation) from your study notes.

■ PHASE 02

5

Visualisation

Present findings through dashboards, reports and charts. Executive summaries for management, technical timelines for analysts, KPI dashboards for ongoing monitoring. Feeds into Phase 03 (SOC & SIEM).

Quiz Answer — Correct Order

Collection → **Parsing** → **Normalisation** → **Analysis** → **Visualisation**

Key Definitions — Log Analysis Terms

Match each log analysis term to its correct definition. These four terms describe distinct stages or operations within the log analysis pipeline.

Parsing

→ Extracting structured fields from raw log text

The process of reading raw log data and breaking it into individual named fields. For example, pulling out timestamp, source IP, event ID and message from an unstructured log string. Parsing happens before normalisation — you must extract the fields before you can standardise them.

Normalisation

→ Converting logs into a consistent format

Transforming parsed fields from many different source formats into a single universal schema. Includes converting timestamps to ISO 8601, mapping severity levels to a unified scale, and enforcing consistent field naming. This is the core focus of Phase 02.

Aggregation

→ Grouping events to identify patterns

Combining normalised events from multiple sources into a unified dataset, then grouping by common attributes (source IP, username, event type) to reveal relationships and patterns that are invisible when looking at individual log sources separately.

Enrichment

→ Adding contextual data from external sources

Enhancing log events with additional context not present in the original log — for example adding geolocation data for an IP address, threat intelligence feed lookups, or user department information from an HR system. Makes events more actionable.

Quick Match Reference

Term	Definition
Parsing	Extracting structured fields from raw log text
Normalisation	Converting logs into a consistent format
Aggregation	Grouping events to identify patterns
Enrichment	Adding contextual data from external sources

CYBER SECURITY OPERATIONS

PHASE 03

SOC & SIEM Functions

DETAILED STUDY NOTES

Monitor · Analyse · Correlate · Detect

NIST PROTECT & NIST DETECT

Feeds into → Phase 04 (Service Management) and Phase 05 (Workflow Automation)

Phase 03 — SOC & SIEM Functions Overview

Phase 03 is the core operational phase of the Cyber Security Operations Process Cycle. The SOC and SIEM work together to monitor, analyse and correlate security events in real-time, using threat intelligence to contextualise data and identify Indicators of Compromise (IOCs).

NIST Framework Mapping: Phase 03 covers both **NIST PROTECT** (safeguards to limit threat impact) and **NIST DETECT** (identifying when a security event has occurred).

The Three Pillars of Phase 03

Threat Intelligence	External and internal knowledge about known threats, attack techniques and adversary behaviour. Fed into the SIEM to give context to raw events. Includes threat feeds, IOC databases (MISP), and vulnerability data. Answers: 'Is this event associated with a known threat?'
SOC & SIEM Functions	The SOC and SIEM work together as the core of Phase 03. The SIEM collects, normalises and correlates events automatically. SOC analysts review alerts, investigate incidents and make decisions. Together they provide 24/7 real-time monitoring of the organisation's security posture.
IOCs — Indicators of Compromise	Forensic evidence that malicious activity has occurred or is occurring. Examples: known malicious IP addresses, suspicious file hashes, unusual domain names, anomalous login patterns. When the SIEM detects an IOC it generates an alert for SOC investigation.

The Phase 03 Cycle

1	Threat intelligence fed into SIEM	Known bad IPs, malware signatures and attack patterns loaded into SIEM rules and watchlists.
2	SIEM monitors all events in real-time	Applies correlation rules, checks against threat intelligence, looks for IOCs continuously.
3	IOC or suspicious pattern detected	SIEM matches an event or pattern against known IOCs or correlation rules — alert generated.
4	SOC analyst investigates the alert	Triage: true positive or false positive? What is the scope? What systems are affected?

Key Phase 03 Terms

IOC	Indicator of Compromise — forensic evidence suggesting malicious activity. e.g. known bad IP, malicious file hash, suspicious domain name.
Threat Intelligence	Knowledge about known threats used to contextualise SIEM events. Includes external feeds, IOC databases and vulnerability data.
Real-time Monitoring	Continuous analysis of security events as they arrive — not batch processing. Enables immediate detection and response.
Contextualisation	Using threat intelligence to add meaning to a raw event — e.g. knowing an IP is on a known-bad list changes how an alert is prioritised.
NIST PROTECT	NIST framework function — putting safeguards in place to limit the impact of a security threat.
NIST DETECT	NIST framework function — identifying when a security event has occurred.

SIEM — Security Information & Event Management

A SIEM system serves as the **central intelligence platform** for an organisation's cybersecurity operations. It combines comprehensive data collection with real-time analysis to detect and respond to security threats.

Core Functionality

A SIEM combines two core components that work together as both a library and a real-time analysis system:

SIM	Security Information Management	Handles long-term storage and analysis of log data. Acts as the organisation's security library — retaining historical data for compliance, forensics and trend analysis.
SEM	Security Event Management	Provides real-time monitoring, correlation of events, and alerts. Acts as the live analyst — watching for patterns and triggering responses as events occur.

SIEM Role Across the Cyber Security Operations Process Cycle

Phase 01	IT Systems Landscape	Connects with infrastructure components identified during initial documentation. Enables comprehensive visibility across the organisation's technology environment.
Phase 02	Aggregation & Normalisation	Standardises incoming data streams, enabling consistent analysis across diverse security information sources. Normalisation creates the foundation for effective threat detection.
Phase 03	SOC & SIEM Functions	Core operational phase — actively monitors and analyses data in real-time. Leverages threat intelligence to contextualise events and identify Indicators of Compromise (IOCs).
Phase 04	Service Management	Generates actionable alerts, facilitates incident tracking, and provides data for security metrics. Ensures systematic handling of identified threats.
Phase 05	Workflow Automation	Enables automated responses through integration with security orchestration tools. Streamlines incident handling and reduces response times.

Phases 06
& 07

Incident Response & Recovery

Provides essential forensic data and supports impact assessment during incidents. Helps verify effectiveness of remediation and supports restoration of normal operations.

Primary SIEM Outcomes

1	Comprehensive Visibility	Across the entire technology infrastructure
2	Rapid Threat Detection	Through real-time monitoring
3	Regulatory Compliance	Through systematic log management
4	Accelerated Response	Through automated workflows
5	Unified Platform	For all security monitoring activity

SIEM Terminology Glossary

Core Concepts

Alert Lifecycle	The complete process through which a security alert moves — from initial detection through investigation, validation, response, and closure. Phases: alert generation, triage, investigation, remediation, and documentation.
Alert Fidelity	The measure of accuracy and reliability in SIEM-generated alerts. High fidelity = minimal false positives and accurate detection. Low fidelity = frequent false alarms requiring additional verification.
Behavioural Analytics	Advanced analysis that establishes normal activity patterns and flags deviations as potential threats. Encompasses User Behaviour Analytics (UBA), Entity Behaviour Analytics (EBA), and Network Behaviour Analytics (NBA).
Correlation Rules	Logical conditions programmed into a SIEM that determine how different security events are connected to identify potential incidents. These rules form the basis for all threat detection and alert generation.
Data Enrichment	Enhancing raw security data with additional context from external sources — threat intelligence feeds, asset databases, user directories, and geographical information. Makes events more actionable.
Event Normalisation	Standardisation process that converts security data from various sources into a consistent format for analysis. Enables unified processing and correlation across diverse data types and sources.

Operational Components

Aggregation Layer	The SIEM component responsible for collecting and consolidating security data from multiple sources across the infrastructure. Handles initial data processing and preparation for analysis.
Baseline Configuration	A documented standard of normal system behaviour used as a reference point for detecting anomalies. Baselines help identify deviations that may indicate security incidents.
Collection Agents	Software components deployed throughout infrastructure to gather security data and forward it to the SIEM. May perform initial filtering and processing before transmission.

Dashboard	Visual interface presenting security information, metrics and alerts in an organised format. Typically includes real-time monitoring, trend analysis, and incident response workflows.
Data Retention	Policies governing how long security data is stored within the SIEM — both active storage for immediate analysis and archived data for compliance and forensic purposes.

Analysis and Response

False Positive	An alert that upon investigation proves to be benign. Managing false positives is critical for operational efficiency and preventing alert fatigue in the SOC team.
Incident Response Integration	The capability to automatically initiate and track incident response procedures based on SIEM alerts — integrating with ticketing systems, automation platforms, and response workflows.
Log Parser	A component that interprets raw log data and extracts relevant security information for analysis. Handles various log formats and protocols, converting them into normalised data structures.
Real-time Analysis	Continuous monitoring and evaluation of security data as it enters the SIEM, enabling immediate detection and response to potential security threats.
Risk-based Alerting	Alert generation approach that considers the risk level of affected assets and the potential impact of detected threats when determining alert priority and response.

Advanced Features

Machine Learning Integration	Use of AI and ML algorithms to enhance threat detection, reduce false positives, and identify complex attack patterns not apparent through traditional rule-based analysis.
Threat Intelligence Platform (TIP) Integration	Capability to incorporate external threat intelligence feeds and Indicators of Compromise (IoCs) into SIEM analysis, providing additional context for threat detection.
Use Case Library	A collection of predefined scenarios and detection rules addressing specific security concerns and compliance requirements. Includes correlation rules, response procedures, and reporting templates.

Compliance and Reporting

Audit Trail	A chronological record of system activities providing documentary evidence of security events and user actions. Essential for compliance requirements and incident investigation.
Compliance Reporting	Automated generation of reports demonstrating adherence to regulatory requirements and security standards. Includes predefined templates and customisable reporting.
Data Classification	Categorisation of security data based on sensitivity, regulatory requirements, and operational importance. Influences data handling, retention, and access control policies.

Performance and Management

Health Monitoring	Continuous tracking of SIEM performance — data collection status, processing delays, and system resource utilisation. Ensures reliable operation and optimal performance.
Scalability	The system's ability to handle increasing data volumes without performance degradation. Includes vertical scaling (adding resources) and horizontal scaling (adding nodes).
Storage Management	Policies for managing SIEM data storage — compression, archiving, and clean-up processes. Ensures efficient storage use while maintaining necessary data availability.

SIEM Workflow — 7 Phase Process Cycle

The SIEM operates across all 7 phases of the Cyber Security Operations Process Cycle. Each phase feeds into the next, with the SIEM acting as the central platform connecting them all.

**Phase
01**

IT Systems Landscape

Identify & document all infrastructure

The SIEM connects to all infrastructure components identified here — servers, network devices, endpoints, applications. This gives it comprehensive visibility across the entire technology environment.

**Phase
02**

Aggregation & Normalisation

Standardise & combine all data

Incoming data streams are normalised into a consistent format. All log sources are aggregated into a single timeline. This is the foundation that makes everything else possible — without this step the SIEM cannot correlate events.

**Phase
03**

SOC & SIEM Functions

Real-time monitoring & threat detection

The core operational phase. The SIEM actively monitors data in real-time, applies correlation rules, leverages threat intelligence, and identifies Indicators of Compromise (IOCs) — forensic evidence of malicious activity.

**Phase
04**

Service Management

Alerts, tracking & security metrics

The SIEM generates actionable alerts, facilitates incident tracking, and produces data for security metrics and KPIs. Ensures all identified threats are handled systematically with clear ownership and accountability.

**Phase
05**

Workflow Automation

Automated response & orchestration

The SIEM triggers automated responses through integration with security orchestration tools (SOAR). Streamlines incident handling, reduces manual effort, and cuts response times significantly.

**Phase
06**

Incident Response

Forensic data & impact assessment

During active security incidents the SIEM provides essential forensic data — full event timelines, affected systems, attack progression. Supports impact assessment and guides the response team's actions.

Phase 07	Recovery	<i>Verify remediation & restore operations</i>
The SIEM helps verify that remediation efforts have been effective by confirming malicious activity has ceased. Supports restoration of normal operations and contributes to post-incident review.		

SIEM Internal Workflow — What Happens Inside the SIEM

This workflow shows the step-by-step process inside the SIEM itself — from raw log ingestion through to threat response. This is different from the 7-Phase Process Cycle (which shows where SIEM fits in the wider organisation). This is what the SIEM actually does.

1

Logs

Raw events from firewalls, servers, applications and network devices.

The starting point — unstructured, varied formats, from many different sources. Nothing has been processed yet. The SIEM receives these continuously in real time.

2

Aggregation

Collecting and counting events to reveal basic patterns and trends.

All incoming logs are pulled together into one place. Events are counted and grouped so the SIEM can begin to see volume-based patterns — e.g. how many failed logins occurred in the last 5 minutes.

3

Normalisation

Converting different log formats into a standardised structure for unified analysis.

All the varied formats (CSV, JSON, syslog, custom) are converted into a single universal schema. Timestamps, severity levels and field names are standardised. This is Phase 02 from your study notes.

4

Correlation

Finding meaningful patterns by examining relationships between events over time.

The most powerful step. Correlation goes beyond counting — it finds relationships between events across different sources. Example: a VPN failure + Windows auth failure + SQL injection from the same IP within 1 minute = one coordinated attack.

5

Alerting

Generating notifications when correlation rules detect suspicious patterns.

When a correlation rule is triggered, the SIEM fires an alert. Good alerting is precise — it fires on genuine threats and avoids alert fatigue from false positives. Alert fidelity is the measure of how accurate these alerts are.

6

Response

Investigating alerts and taking action to contain and remediate threats.

The final step — analysts investigate the alert and take action. This may be manual (SOC analyst) or automated (SOAR playbook). The goal is to contain the threat and restore normal operations as quickly as possible.

Key Distinction — Aggregation vs Correlation

Aggregation Only	Correlation Pattern
Counts events but misses patterns. Example: sees 3 separate failed logins — treats each one individually. No connection is made between them.	Finds relationships between events. Example: sees 3 failed logins from the same IP across different systems within 1 minute — flags as a coordinated brute force attack.

Lab 4 — SIEM Correlation, Alerting & Alert Lifecycle

This lab covers the core concepts behind SIEM correlation rules, the false positive problem, alert fidelity, and the full alert lifecycle. These concepts underpin every real-world SOC operation.

"Aggregation shows you WHAT happened. Correlation shows you WHAT IT MEANS."

What is a Correlation Rule?

A correlation rule is a logical condition that connects multiple events based on relationships — not just counts. It uses time windows, source identifiers, and thresholds to determine whether a pattern constitutes a threat.

Why Correlation is More Powerful than Aggregation

Aggregation counts events. Correlation finds the meaning behind them. The critical difference is **time context**:

Aggregation Only	Correlation
Sees: 6 failed logins Conclusion: nothing — just a number.	Sees: 6 failed logins from same IP within 90 seconds Conclusion: BRUTE FORCE ATTACK
<i>6 attempts over 6 hours = NORMAL</i>	6 attempts in 90 seconds = ATTACK

Example — Brute Force Detection Correlation Rule

IF	5 or more failed login attempts
AND	From the same source IP address
AND	Within a 120 second time window
AND	On SSH service
THEN	Generate alert: Brute Force Detected — severity HIGH

How the Rule is Implemented (4 Steps)

Step 1 — Filter	Filter data to only SSH failed login events (like a SQL WHERE clause)
Step 2 — Sort	Sort all filtered events chronologically
Step 3 — Group	Group events by source IP (like a SQL GROUP BY clause)

Step 4 — Sliding Window

For each event, check if 5 or more events from the same IP follow within 120 seconds. This is the sliding window — it moves forward with each event, checking the pattern.

Checking if an Attack Succeeded

After detecting brute force, check whether it worked:

```
grep "192.168.1.100" data/sample_logs.csv | grep "successful_login"
```

If a `successful_login` appears after the failed attempts from the same IP — the attacker got in. This moves the alert from attempted to confirmed breach.

The False Positive Problem

False positives are one of the most common challenges every SOC analyst faces. A false positive is an alert that fires on legitimate, benign activity rather than a real threat.

Example Scenario

192.168.1.100	TRUE POSITIVE — actual brute force attack	Multiple failed SSH logins in quick succession. Username: admin/root. External IP. No documented legitimate use. This IS an attack.
10.0.0.5	FALSE POSITIVE — monitoring server	Multiple SSH connection attempts but: username is 'monitor', attempts occur at exactly every 2 minutes (automated), internal RFC 1918 IP, documented as known infrastructure. This is NOT an attack.

Alert Fidelity Analysis

Metric	Value
Total Alerts	2
True Positives	1 (192.168.1.100 — actual attack)
False Positives	1 (10.0.0.5 — monitoring server)
Alert Fidelity	50% accuracy

Why False Positives Matter

Alert Fatigue	Analysts start ignoring alerts when too many are false — real attacks get missed
Wasted Time	Investigating benign activity burns analyst hours that should go to real threats
Missed Threats	Real attacks get buried in the noise of false positive alerts
Resource Drain	Automated responses triggered unnecessarily — blocking legitimate traffic

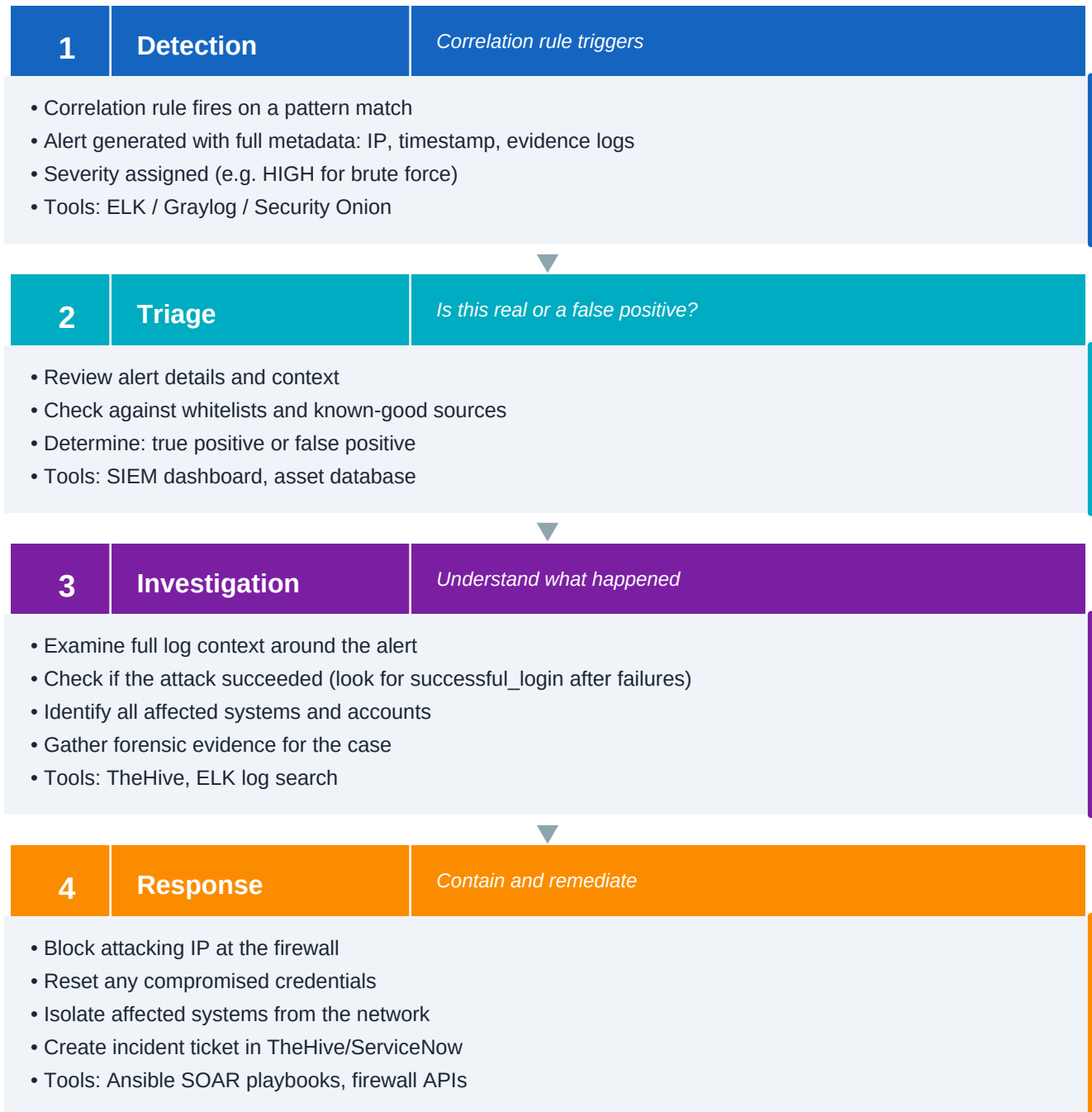
How to Identify a False Positive (10.0.0.5 example)

- Username is 'monitor' — not 'admin' or 'root' which attackers typically target
- Regular interval: exactly every 2 minutes — automated behaviour, not human
- Internal IP: 10.0.0.5 is RFC 1918 private range — not external attacker
- Known infrastructure: documented monitoring system in asset database

Fix: Add 10.0.0.5 to a whitelist in the correlation rule. Enterprise SIEMs generate thousands of alerts daily — tuning correlation rules to reduce false positives is a critical and ongoing SOC skill.

The Complete Alert Lifecycle

Every alert generated by a SIEM moves through a defined lifecycle from detection to closure. Understanding this lifecycle is essential for designing effective SOC workflows and tool integrations.



- Record all actions taken during the incident
- Update correlation rules if the attack revealed a gap
- Add attacker indicators to threat intelligence (MISP)
- Close the alert/case with full documentation
- Tools: MISP, TheHive, ticketing systems

Lab 4 — Key Takeaways

- Correlation finds patterns across time — aggregation just counts events
- Time windows are what make correlation powerful: 6 logins in 6 hours $\neq$ 6 logins in 90 seconds
- Alert fidelity = ratio of true positives to total alerts — higher is better
- False positives cause alert fatigue, wasted time, missed threats and resource drain
- Whitelist known-good sources (monitoring servers, scanners) to reduce false positives
- Tuning correlation rules is a critical and ongoing skill for every SOC analyst
- Enterprise SIEMs generate thousands of alerts daily — most SOC time is spent on false positive investigation
- The Alert Lifecycle has 5 phases: Detection → Triage → Investigation → Response → Documentation

Tool Correlation Features — Match Reference

Each open-source SIEM tool implements correlation logic differently. These are the correct matches from the quiz — learn both the tool name and exactly how it implements correlation.

ELK Stack

→ XML rules with frequency and timeframe tags

Elasticsearch/Kibana uses SIEM detection rules written in a structured format that specifies how frequently an event must occur and within what timeframe. Rules are defined with frequency counts and time window parameters to detect patterns like repeated failures within a set period.

Graylog

→ Detection Rules with threshold queries

Graylog implements correlation through its alert system using threshold-based queries. You define a search query and set a threshold — when the count of matching events exceeds the threshold within a time window, an alert fires.

Security Onion

→ Suricata/Zeek signature rules

Security Onion bundles Suricata (IDS/IPS) and Zeek (network analysis). Correlation is handled through Suricata signature rules that match network patterns, and Zeek scripts that analyse network behaviour and relationships between connections.

Wazuh

→ Correlation Engine and Event Definitions

Wazuh has a dedicated correlation engine that links related events using defined event rules. Rules specify parent-child relationships between events and can chain alerts together — e.g. a failed login followed by a successful one triggers a composite alert.

Quick Match Reference

Tool	Correlation Feature
ELK Stack	XML rules with frequency and timeframe tags
Graylog	Detection Rules with threshold queries
Security Onion	Suricata/Zeek signature rules
Wazuh	Correlation Engine and Event Definitions

Key Definitions — Open Book Reference

All key terms that have appeared in the quiz but were not explicitly defined in the source documents. Use this page as your first stop in an open book exam.

Correlation Key	<i>The field used to group related events together</i>	e.g. source_ip. Determines which events belong to the same pattern. In a brute force rule, source_ip is the correlation key because all failed logins must come from the same IP to count as one attack.
Correlation Rule	<i>A logical condition that connects multiple events to detect a threat pattern</i>	Goes beyond counting — uses time windows, correlation keys and thresholds to find relationships between events. Example: 5+ failed logins from same IP within 120 seconds.
Time Window	<i>The time period within which events must occur to trigger a correlation rule</i>	e.g. 120 seconds. Six failed logins in 6 hours = normal. Six in 90 seconds = attack. The time window is what makes correlation powerful.
Alert Fidelity	<i>The accuracy of SIEM alerts — ratio of true positives to total alerts</i>	High fidelity = mostly real threats. Low fidelity = too many false positives. 50% fidelity means half your alerts are false alarms.
True Positive	<i>An alert that correctly identifies a real security threat</i>	e.g. 192.168.1.100 triggering a brute force alert when it genuinely is attacking. The alert is correct.
False Positive	<i>An alert that fires on legitimate, benign activity — not a real threat</i>	e.g. 10.0.0.5 monitoring server triggering a brute force alert. The activity is legitimate but the rule cannot tell the difference without tuning.
Alert Fatigue	<i>When analysts start ignoring alerts because too many are false positives</i>	A major real-world problem. If 90% of alerts are false, analysts stop investigating carefully — and real attacks get missed.
Sliding Window	<i>A correlation technique that checks for patterns within a moving time period</i>	For each new event, it looks back (or forward) a fixed time period to see if enough related events have occurred. Moves forward with each event rather than being fixed.
Whitelist	<i>A list of known-good sources that are excluded from triggering alerts</i>	e.g. adding 10.0.0.5 to a whitelist so the monitoring server never triggers the brute force rule. Essential for reducing false positives.
Threshold	<i>The minimum count of events required to trigger a correlation rule</i>	e.g. 5 failed logins. Below the threshold = no alert. At or above = alert fires. Setting the right threshold balances detection sensitivity vs false positives.

IOC — Indicator of Compromise	<i>Forensic evidence that suggests malicious activity has occurred</i>	e.g. a specific IP address, file hash, domain name, or behavioural pattern associated with known attacks. SIEMs use IOCs from threat intelligence feeds to enrich alerts.
Normalisation	<i>Converting logs from different sources into a single consistent format</i>	Standardises timestamps (ISO 8601), severity levels, field names. Makes events from firewalls, Windows, IDS and VPN comparable and queryable together.
Aggregation	<i>Combining events from multiple sources and grouping them to reveal patterns</i>	Collects, counts and groups events. Shows WHAT happened. Cannot on its own show temporal relationships — that requires correlation.
Enrichment	<i>Adding contextual data from external sources to a security event</i>	e.g. adding geolocation to an IP, or threat intelligence tags to a known-bad domain. Makes events more actionable for analysts.
Parsing	<i>Extracting structured fields from raw log text</i>	The step before normalisation. Reads the raw log string and pulls out individual named fields (timestamp, IP, event type etc.) based on the log format.
SIEM	<i>Security Information and Event Management — central security monitoring platform</i>	Combines SIM (long-term log storage) and SEM (real-time event monitoring). Collects, normalises, correlates and alerts on security events across the organisation.
SIM	<i>Security Information Management — long-term log storage and analysis</i>	The library component of a SIEM. Handles data retention, compliance reporting and historical forensic analysis.
SEM	<i>Security Event Management — real-time monitoring and alerting</i>	The live analyst component of a SIEM. Monitors events as they arrive, applies correlation rules, and generates alerts in real time.

CYBER SECURITY OPERATIONS

PHASE 04

Service Management Integration

DETAILED STUDY NOTES

Efficient delivery · Monitoring · Continuous improvement

NIST GOVERN

Feeds into → Phase 05 (Workflow Automation)

Phase 04 — Service Management Integration

Service Management Integration is the bridge between security monitoring and operational response. It ensures the efficient delivery, monitoring, and continuous improvement of security services by aligning operational processes with organisational objectives and incident response workflows.

NIST GOVERN — Phase 04 establishes the governance layer: policies, processes and oversight that ensure security services are delivered consistently.

Core Components

Incident Management Integration	Links security alerts to IT service management workflows. Automates ticket creation for security incidents, tracks the incident lifecycle from detection to resolution, and enables consistent response procedures across the organisation.
Service Level Agreements (SLAs)	Documented commitments regarding response times and service quality metrics. Defines response timeframes based on incident severity, establishes performance metrics for security operations, and monitors compliance with service commitments.
Continuous Service Improvement	Ongoing process of measuring and improving security service effectiveness. Identifies areas for process optimisation, implements improvements based on operational feedback, and tracks and reports on service performance metrics.

Primary Objectives

- Ensure consistent security service delivery
- Maintain service quality standards
- Enable efficient incident response
- Support continuous service improvement
- Align security operations with business objectives

Integration Methods

API Integration	Connects security tools with service management platforms. Enables automated ticket creation and updates. Facilitates bi-directional information flow.
Workflow Integration	Defines standard operating procedures and escalation paths. Ensures consistent incident handling across all teams.
Reporting Integration	Provides service performance metrics, tracks SLA compliance, and generates management reports.
Tool Integration	Links security tools with ITSM platforms. Enables automated workflow triggers and supports coordinated response actions.

Success Metrics

MTTD	Mean Time to Detect — average time to identify security incidents
MTTR (Respond)	Mean Time to Respond — average time to initiate response to identified incidents
MTTR (Resolve)	Mean Time to Resolve — average time to completely resolve security incidents
SLA Compliance Rate	Percentage of incidents handled within defined service levels

Phase 04 — Key Terminology Glossary

Change Management	Controlled process of planning, testing, implementing, documenting and reviewing changes to services or infrastructure. Includes emergency, standard and normal changes.
CMDB	Configuration Management Database — repository of all hardware and software component information and the relationships between them.
Continuous Service Improvement (CSI)	Ongoing process of measuring and improving the quality of services and overall service management maturity.
SLA	Service Level Agreement — documented agreement defining expected service levels, metrics, responsibilities and penalties.
OLA	Operational Level Agreement — internal agreement defining how different IT groups support external SLAs.
KPI	Key Performance Indicator — metric used to evaluate the success of service delivery and organisational objectives.
Service Catalog	Structured document listing all IT services available, including descriptions, SLAs, costs and request procedures.
Incident	Any unplanned interruption or reduction in quality of an IT service.
Major Incident	High-impact, high-urgency incident requiring escalated response and increased coordination.
Problem	The underlying cause of one or more incidents.
Known Error	A problem that has been analysed but not yet resolved.
Alert Correlation	Connecting multiple related alerts or incidents to identify patterns and root causes.
Automation Workflow	Predefined sequences of activities that can be automatically executed in response to specific triggers.
Escalation Path	The defined route through which incidents are passed to progressively higher levels of support or management.
BIA	Business Impact Analysis — assessment of the potential effects of service disruptions on business operations.
MTTD	Mean Time to Detect — average time between onset of an incident and its detection.
MTTR	Mean Time to Resolve — average time between incident detection and complete resolution.

RTO	Recovery Time Objective — targeted duration within which a service must be restored after a disruption.
Audit Trail	Chronological record of activities and changes within the service management system.
Capacity Management	Process of ensuring IT service capacity meets current and future business requirements.
Service Review	Regular assessment of service performance against defined objectives and SLAs.

Phase 04 Across the Process Cycle

Phase 01	Maps service dependencies, identifies critical systems, establishes service catalogues.
Phase 02	Integrates service management tools with security monitoring, standardises incident categorisation.
Phase 03	Provides real-time service impact assessment, enables automated service ticket creation.
Phase 04	PRIMARY — ensures efficient delivery, continuous monitoring, and service improvement.
Phase 05	Automates routine service management tasks, streamlines incident handling.
Phase 06	Coordinates response activities, tracks incident resolution progress.
Phase 07	Manages service restoration, tracks remediation effectiveness.

Alert-to-Ticket Workflow

When a SIEM correlation rule fires, the alert does not stay in the SIEM — it flows through a structured workflow to become a managed ticket with an assigned team, SLA deadline, and notification trail. This is Phase 04 in action.

1

Alert Generated

Security correlation rule triggers on suspicious activity.

```
alert_id: BF-20260213-1921681100  
  
source_ip: 192.168.1.100  
  
event_count: 6  
  
timestamp: 09:16:15
```

2

Calculate Severity

Apply rules: event count + timing + whitelist check.

```
Event count: 6 → HIGH  
  
Time: 09:16 (business hours)  
  
IP: Not whitelisted  
  
RESULT: HIGH severity
```

3

Lookup SLA

Determine response time and team assignment based on severity.

```
Severity: HIGH  
  
Response Time: 60 minutes  
  
Team: Security Operations Centre  
  
Priority: 2
```

4

Create Ticket

Build structured ticket with all metadata attached.

```
ticket_id: TKT-BF-20260213-1921681100  
  
title: Brute Force: 192.168.1.100  
  
status: Open  
  
sla_deadline: 10:16:15 (+60 min)
```

5

Route & Notify

Assign to team and send notifications via all channels.

Team: Security Operations Centre

Email: soc@company.local

Slack: #soc-alerts

Ticket active in queue

Key Point: The SLA deadline is set at ticket creation — not when the analyst picks it up. The clock starts the moment the alert fires. This is why Phase 04 integration matters: without it, response times are unmeasured and unmanaged.

CYBER SECURITY OPERATIONS

PHASE 05

Workflow Automation

DETAILED STUDY NOTES

Automate · Orchestrate · Respond faster

NIST PROTECT · NIST DETECT · NIST RESPOND

Feeds into → Phase 06 (Incident Response)

Phase 05 — Workflow Automation

Workflow Automation in Cyber Security is the systematic automation of repetitive tasks, incident response, and threat management processes to enable faster decision-making and reduce human error. It integrates with NIST PROTECT, DETECT, and RESPOND frameworks.

NIST Mapping: Phase 05 spans NIST PROTECT (automated safeguards), NIST DETECT (automated detection) and NIST RESPOND (automated response actions).

Key Components

Process Automation	Automated alert triage and categorisation. Standardised response procedures. Automatic ticket creation and routing. Systematic data collection and analysis.
Decision Support	Automated systems that help analysts make informed decisions by providing relevant context and recommendations. Includes threat intelligence correlation, risk assessment automation, impact analysis, and response recommendation engines.
SOAR Platforms	Security Orchestration, Automation and Response — platforms that combine orchestration, automation and incident response to improve security operations efficiency. Examples: TheHive (open source), Splunk Phantom, IBM Security SOAR, Palo Alto Cortex XSOAR.

Integration Methods

API Integration	Connects different security tools and enables automated data exchange. Facilitates coordinated actions across the toolchain.
Event-Driven Automation	Triggers based on specific events. Executes predefined responses and maintains response consistency.
Conditional Logic	Decision-based workflow routing. Dynamic response selection and context-aware automation.

Primary Objectives

Efficiency

- Reduce manual intervention
- Accelerate response times
- Improve resource utilisation

Consistency

- Standardise processes
- Ensure procedure compliance

- Maintain response quality

Error Reduction

- Minimise human error
- Ensure complete execution
- Validate actions

Scale Support

- Handle increasing workloads
- Maintain performance
- Enable growth

Success Metrics

Automation Rate	Percentage of tasks automated vs manual
Time Savings	Reduction in time spent on routine tasks
Error Reduction	Decrease in mistakes or incomplete actions
Response Time	Improvement in incident response speed

Benefits

- Faster incident response
 - Reduced manual effort
 - Consistent execution
 - Improved scalability
- Better resource utilisation
 - Enhanced decision-making
 - Improved compliance
 - Increased efficiency
- Reduced operational costs
 - Better resource allocation
 - Improved ROI
 - Enhanced productivity

Phase 05 — Workflow Automation Glossary

Automation	Use of technology to perform tasks with minimal human intervention. In security, automates repetitive operations and response procedures.
Workflow	A sequence of steps that process data or accomplish a specific objective. Defines order of operations and decision points.
Orchestration	Coordination and management of multiple automated tasks, systems or services to execute complex workflows with proper sequencing.
Playbook	Predefined set of automated procedures for handling specific security scenarios. Contains step-by-step instructions for automated response.
Runbook	Detailed technical documentation describing steps for completing a task, including automated procedures and manual interventions.
SOAR	Security Orchestration, Automation and Response — platforms combining orchestration, automation and incident response capabilities.
Security Playbook	Specialised playbook focused on security incident response and threat mitigation procedures.
Trigger	Event or condition that initiates an automated workflow. Can be time-based, event-based, alert-based, or manual.
Action	A specific task or operation performed as part of a workflow — data processing, system configuration, or communication.
Condition	Logical test that determines the flow of automation based on specific criteria. Enables dynamic routing and decision-making.
Webhook	Automated message sent from one application to another when a specific event occurs. Enables real-time workflow triggers.
API	Application Programming Interface — protocols that allow different software applications to communicate and share data.
Connector	Pre-built integration component enabling communication between different systems in an automated workflow.
Data Mapping	Matching fields and data structures between different systems to ensure proper data transfer in automated workflows.
Middleware	Software that acts as a bridge between different applications, systems and databases in an automated workflow.
Alert Automation	Automatic processing and routing of security alerts based on predefined rules and conditions.

Incident Response Automation	Automated procedures for handling security incidents, including investigation and remediation steps.
Exception Handling	Procedures for managing and responding to errors or unexpected conditions in automated workflows.
Fallback Procedure	Alternative actions implemented when primary automation fails or encounters errors.
Low-Code/No-Code	Development approaches enabling workflow automation creation with minimal programming requirements.
Version Control	System for tracking and managing changes to automated workflows and their components.
Task Queue	System component that manages and orders tasks for processing, ensuring proper sequence and resource allocation.

Phase 05 Across the Process Cycle

Phase 01	Automates system discovery, maintains asset inventory, tracks configuration changes.
Phase 02	Automates data collection, standardises formats, performs initial correlation.
Phase 03	Automates alert generation, performs initial threat analysis, initiates response workflows.
Phase 04	Creates incident tickets, routes alerts to teams, tracks SLA compliance.
Phase 05	PRIMARY — streamlines repetitive tasks, accelerates incident response, reduces human error.
Phase 06	Automates initial response actions, coordinates team activities, documents incident details.
Phase 07	Automates recovery procedures, validates remediation actions, tracks effectiveness.

Key Automation Tools

TheHive	Open-source incident response platform. Case management, alert triage automation, integration with MISP.
Splunk Phantom	Enterprise SOAR. Extensive integrations, custom playbook creation, rich API ecosystem.
Cortex XSOAR	Palo Alto SOAR. Multi-source orchestration, automated investigation, collaborative platform.
Ansible	Security configuration automation. Playbook-based, multi-platform, agentless architecture.
ServiceNow SecOps	Security incident management, automated workflows, SLA management, CMDB integration.

Python	Primary scripting language for security automation. API integration, data processing, custom tool development.
Zapier / Power Automate	Cloud workflow automation. No-code/low-code, trigger-based actions, broad tool integrations.

ADDENDUM — Additional Detail: Phase 04 & Phase 05

This addendum extends your existing Phase 04 and Phase 05 study notes with all detail from the Service Management Insights and Workflow Automation Insights documents, plus the complete Alert-to-Ticket Workflow for Phase 04.

PHASE 04

Service Management Integration

Efficient delivery · Monitoring · Continuous improvement

Alert-to-Ticket Workflow — Phase 04 in Action

When a SIEM correlation rule fires, the alert does not stay in the SIEM — it flows through a structured 5-step workflow to become a fully managed ticket with an assigned team, SLA deadline, and notification trail. The SLA deadline is set at ticket creation, not when the analyst picks it up. The clock starts the moment the alert fires. Without this integration, response times are unmeasured and unmanaged.

Step 1 — Alert Generated

Security correlation rule triggers on suspicious activity.

Field	Value
alert_id	BF-20260213-1921681100
source_ip	192.168.1.100
event_count	6
timestamp	09:16:15

Step 2 — Calculate Severity

Apply rules: event count + timing + whitelist check.

Rule Check	Input	Result
Event count	6 failed login attempts	→ HIGH (threshold exceeded)
Time of day	09:16 (business hours)	→ Elevated concern
Whitelist check	192.168.1.100	→ NOT whitelisted
FINAL SEVERITY		HIGH

Step 3 — Lookup SLA

Determine response time and team assignment based on severity.

Field	Value
Severity	HIGH
Response Time	60 minutes
Team	Security Operations Centre

Priority	2
----------	---

Step 4 — Create Ticket

Build structured ticket with all metadata attached.

Field	Value
ticket_id	TKT-BF-20260213-1921681100
title	Brute Force: 192.168.1.100
status	Open
sla_deadline	10:16:15 (+60 min from alert time)
severity	HIGH
team_assigned	Security Operations Centre
priority	2

Step 5 — Route & Notify

Assign to team and send notifications via all channels.

Channel	Destination	Content
Team Assignment	Security Operations Centre	Ticket assigned to SOC queue
Email	soc@company.local	Alert notification with ticket details and SLA deadline
Slack	#soc-alerts	Real-time notification with ticket link and severity
Ticket System	Active in SOC queue	Ticket TKT-BF-20260213-1921681100 now open

KEY POINT: The SLA deadline is set at ticket CREATION — not when the analyst picks it up. The clock starts the moment the alert fires. This is why Phase 04 integration matters: without it, response times are unmeasured and unmanaged.

Service Management Integration — Full Detail

Service Management Integration in Cyber Security Operations represents the bridge between security monitoring and operational response. Based on Phase 04, it focuses on ensuring efficient delivery, monitoring, and continuous improvement of security services.

Relationship to Process Cycle Phases

- **Phase 01 (IT Systems):**
 - Maps service dependencies
 - Identifies critical systems requiring priority response
 - Establishes service catalogs for security operations
- **Phase 02 (Aggregation):**
 - Integrates service management tools with security monitoring
 - Ensures proper data flow for incident creation
 - Standardises incident categorisation
- **Phase 03 (SOC & SIEM):**
 - Provides real-time service impact assessment
 - Enables automated service ticket creation

- Links security events to affected services
- **Phase 04 (Service Management) ★ PRIMARY:**
 - Ensures efficient delivery of security services
 - Maintains continuous monitoring
 - Implements service improvement processes
 - Aligns with organisational objectives
- **Phase 05 (Workflow Automation):**
 - Automates routine service management tasks
 - Streamlines incident handling procedures
 - Reduces manual intervention requirements
- **Phase 06 (Incident Response):**
 - Coordinates response activities
 - Tracks incident resolution progress
 - Ensures compliance with response procedures
- **Phase 07 (Remediation):**
 - Manages service restoration activities
 - Tracks remediation effectiveness
 - Ensures service level recovery

Key Terminology

Term	Definition
Change Management	Process of controlling modifications to infrastructure, ensuring security impacts are assessed.
Service Catalogue	Documented inventory of available security services and their associated service levels.
CMDB	Configuration Management Database — repository of IT infrastructure information and service relationships.
OLA	Operational Level Agreement — internal agreements defining how different IT groups work together to support SLAs.
KPI	Key Performance Indicators — metrics used to evaluate the effectiveness of security service delivery.
Audit Trail	Chronological record of activities and changes within the service management system.
Compliance Framework	Structure of policies, procedures, and controls designed to ensure adherence to regulatory requirements.
Service Review	Regular assessment of service performance against defined objectives and SLAs.
API Integration	Connection between different systems using Application Programming Interfaces to enable automated data exchange.
Dashboard	Visual display of service performance metrics, operational status, and other key indicators.
Service Desk Platform	Central system for managing service requests, incidents, and other service management processes.
Workflow Engine	Software component that manages and executes defined process workflows.

Capacity Management	Process of ensuring that IT service capacity meets current and future business requirements.
Knowledge Base	Repository of information about services, including troubleshooting guides, solutions, and best practices.
Skill Matrix	Documentation of team member capabilities and expertise related to service management functions.
Communication Plan	Structured approach to sharing information about service status, changes, and incidents with stakeholders.
Service Design	Phase where new or changed services are developed and documented.
Service Transition	Process of moving new or changed services into operational status.
Service Operation	Day-to-day management and support of live services.
Service Retirement	Controlled process of removing services from active use.
Business Impact Analysis (BIA)	Assessment of the potential effects of service disruptions on business operations.
Recovery Time Objective (RTO)	The targeted duration of time within which a service must be restored after a disruption.

Service Management Without a SOC

Service Management can and often does exist without a Security Operations Centre (SOC). Key adaptations required:

- **Modified Response Procedures:**
 - Clear escalation paths for security incidents
 - Defined security incident categories
 - Basic security response playbooks
 - Integration with external security providers if needed
- **Alternative Security Controls:**
 - Managed Security Service Providers (MSSPs)
 - Automated security tools and platforms
 - Third-party security monitoring services
 - Cloud security services
- **Compensating Measures:**
 - Enhanced logging and monitoring
 - Regular security assessments
 - Incident response retainers
 - Security awareness training

Challenges Without a SOC

- Limited Specialised Expertise — may lack deep security expertise; slower response to complex threats; potential for missed security incidents; less proactive threat hunting.
- Resource Constraints — security competes with other IT priorities; limited dedicated resources; potential gaps in 24/7 coverage; reduced monitoring capability.
- Integration Complexities — security tools may be underutilised; less sophisticated threat correlation; limited security metrics and reporting; reduced automation capabilities.

Best Practices for Organisations Without a SOC

- **Clear Security Responsibilities:**

- Designate security points of contact
- Define security incident procedures
- Establish escalation paths
- Document security processes
- **Enhanced Training:**
 - Security awareness for IT staff
 - Basic incident response training
 - Security tool operation training
 - Threat recognition skills
- **Strong Partnerships:**
 - Relationships with security vendors
 - External security expertise access
 - Incident response support
 - Regular security assessments
- **Focused Security Controls:**
 - Critical asset protection
 - Essential security monitoring
 - Basic threat detection
 - Incident response capabilities

Workflow Automation — Full Detail

Workflow Automation in Cyber Security is the systematic automation of repetitive tasks, incident response, and threat management processes to enable faster decision-making and reduce human error. Integrates with NIST PROTECT, DETECT, and RESPOND frameworks.

Relationship to Process Cycle Phases

- **Phase 01 (IT Systems):**
 - Automates system discovery and documentation
 - Maintains asset inventory
 - Updates system relationships
 - Tracks configuration changes
- **Phase 02 (Aggregation):**
 - Automates data collection
 - Standardises data formats
 - Performs initial correlation
 - Maintains data quality
- **Phase 03 (SOC & SIEM):**
 - Automates alert generation
 - Performs initial threat analysis
 - Correlates security events
 - Initiates response workflows
- **Phase 04 (Service Management):**
 - Creates incident tickets
 - Routes alerts to appropriate teams
 - Tracks SLA compliance
 - Manages escalation procedures
- **Phase 05 (Workflow Automation) ★ PRIMARY:**
 - Streamlines repetitive tasks
 - Accelerates incident response
 - Reduces human error
 - Enables faster decision-making
- **Phase 06 (Incident Response):**
 - Automates initial response actions
 - Coordinates team activities
 - Tracks response progress
 - Documents incident details
- **Phase 07 (Remediation):**
 - Automates recovery procedures
 - Validates remediation actions
 - Updates security controls
 - Tracks effectiveness

Cyber Security Workflow Automation Tools and Technologies

SOAR — Security Orchestration, Automation and Response Platforms

Tool	Type	Key Capabilities
Splunk Phantom	Enterprise	Enterprise-grade SOAR. Extensive integration capabilities. Custom playbook creation. F
IBM Security SOAR (formerly Resilient)	Enterprise	Comprehensive incident response automation. Dynamic playbooks. Threat intelligence.
Palo Alto Cortex XSOAR (formerly Cortex Xpanse)	Enterprise	Multi-source security orchestration. Automated investigation. Collaborative investigation.
TheHive	Open Source	Open-source incident response platform. Case management. Alert triage automation. In
WALKOFF	Open Source	NSA-developed automation framework. Modular architecture. Custom workflow creation.

Robotic Process Automation (RPA) Tools

Tool	Key Capabilities
UiPath	Process automation for security tasks. Screen scraping capabilities. Automated data entry. Task recording and m
Automation Anywhere	Bot-based automation. Cognitive automation features. Process discovery. Analytics and reporting.

Integration Platforms — API & Enterprise Service Bus

Tool	Category	Key Capabilities
Zapier	API / No-code	Cloud service integration. Automated workflows. Trigger-based actions. No-code automa
Microsoft Power Automate	API / No-code	Enterprise workflow automation. Office 365 integration. Custom connectors. AI-powered
MuleSoft	ESB	API-led connectivity. Service orchestration. Data transformation. Security policy enforc
Apache ServiceMix	ESB	Open-source integration. Protocol conversion. Message routing. Service orchestration.

Incident Response Platforms

Tool	Key Capabilities
ServiceNow Security Operations	Security incident management. Automated workflows. SLA management. Integration with CMDB.
Jira Service Management	Security issue tracking. Customisable workflows. Automation rules. Team collaboration.

Custom Development Tools

Tool	Category	Key Capabilities
Python	Scripting	Security automation scripts. API integration. Data processing. Custom tool development.
PowerShell	Scripting	Windows automation. Security administration. System management. Active Directory integration.
Node-RED	Framework	Flow-based programming. Visual workflow creation. IoT integration. Event-driven automation.
Apache NiFi	Framework	Data flow automation. Process governance. System integration. Security and encryption.

SIEM Tools with Automation Capabilities

Tool	Key Capabilities
Splunk Enterprise Security	Log aggregation. Alert automation. Correlation rules. Response workflows.

QRadar	Security intelligence. Automated investigation. Use case library. Custom rule creation.
--------	---

Threat Intelligence Platforms

Tool	Key Capabilities
ThreatConnect	Intelligence automation. Workflow orchestration. Indicator enrichment. Automated analysis.
Recorded Future	Real-time intelligence. Risk assessment. Alert automation. API integration.

Infrastructure & Cloud Automation

Tool	Category	Key Capabilities
Ansible	Config Mgmt	Security configuration automation. Playbook-based. Multi-platform support. Agentless architecture.
Puppet	Config Mgmt	Configuration enforcement. Security compliance. Change management. Policy automation.
AWS Systems Manager	Cloud	Automated operations. Security patching. Configuration management. Resource compliance.
Azure Automation	Cloud	Process automation. Configuration management. Update management. Security automation.
Elasticsearch Stack	Monitoring	Log analysis automation. Alert generation. Visualisation. Machine learning capabilities.
Prometheus & Grafana	Monitoring	Metric collection. Alert automation. Dashboard creation. Performance monitoring.

Integration Considerations — Key Features to Evaluate

- **API Capabilities:**
 - REST API support
 - GraphQL integration
 - Authentication methods
 - Rate limiting
- **Scalability:**
 - Concurrent execution
 - Resource management
 - Performance optimisation
 - Load distribution
- **Security:**
 - Access control
 - Audit logging
 - Encryption
 - Compliance support
- **Usability:**
 - Visual workflow builder
 - Template library
 - Documentation
 - Community support

Workflow Automation Terminology Glossary

Term	Definition
Automation	The use of technology to perform tasks with minimal human intervention. In security contexts, involves automating repetitive security operations and response procedures.

Workflow	A sequence of steps or tasks that process data or accomplish a specific business objective. Workflows define the order of operations and decision points in a process.
Orchestration	The coordination and management of multiple automated tasks, systems, or services to execute complex workflows. Ensures proper sequencing and handling of dependencies.
API (Application Programming Interface)	A set of protocols and tools that allow different software applications to communicate and share data. APIs are fundamental to workflow automation integration.
Playbook	A predefined set of automated procedures designed to handle specific security scenarios or incidents. Contains step-by-step instructions for automated response.
Runbook	Detailed technical documentation describing the steps for completing a task or process, often including automated procedures and manual interventions when needed.
Webhook	An automated message sent from one application to another when a specific event occurs. Webhooks enable real-time workflow triggers and integrations.
Trigger	An event or condition that initiates an automated workflow. Triggers can be based on time, events, alerts, or manual activation.
Action	A specific task or operation performed as part of a workflow. Actions can include data processing, system configuration, or communication tasks.
Condition	A logical test that determines the flow of automation based on specific criteria. Conditions enable dynamic workflow routing and decision-making.
Task Queue	A system component that manages and orders tasks for processing, ensuring proper sequence and resource allocation.
Connector	A pre-built integration component that enables communication between different systems or applications in an automated workflow.
Data Mapping	The process of matching fields and data structures between different systems to ensure proper data transfer in automated workflows.
Middleware	Software that acts as a bridge between different applications, systems, and databases in an automated workflow.
SOAR	Security Orchestration, Automation and Response — platforms combining security orchestration, automation, and incident response capabilities to improve security operations efficiency.
Alert Automation	The automatic processing and routing of security alerts based on predefined rules and conditions.
Incident Response Automation	Automated procedures for handling and responding to security incidents, including investigation and remediation steps.
Security Playbook	A specialised type of playbook focused on security incident response and threat mitigation procedures.
Audit Trail	A chronological record of automated workflow activities, including actions taken, changes made, and decision points.
Monitoring Dashboard	A visual interface displaying the status, performance, and metrics of automated workflows.

Performance Metrics	Measurements used to evaluate the efficiency and effectiveness of automated workflows.
Service Level Indicator (SLI)	Metrics that indicate the level of service provided by automated workflows.
Low-Code/No-Code	Development approaches that enable workflow automation creation with minimal programming requirements.
Version Control	System for tracking and managing changes to automated workflows and their components.
Exception Handling	Procedures for managing and responding to errors or unexpected conditions in automated workflows.
Fallback Procedure	Alternative actions or processes implemented when primary automation fails or encounters errors.
Error Log	A record of issues, failures, and exceptions encountered during workflow execution.
Recovery Process	Procedures for restoring normal workflow operation after failures or interruptions.
Load Balancing	Distribution of workflow processing across multiple resources to optimise performance and reliability.
Scaling	Adjusting workflow automation capacity to handle varying workload demands.
Workflow Policy	Rules and guidelines governing the creation, modification, and execution of automated workflows.
Compliance Checking	Automated verification of workflow adherence to regulatory and organisational requirements.
Workflow Analytics	Collection and analysis of workflow performance data to identify improvement opportunities.
Process Mining	Analysis of workflow execution data to discover, monitor, and improve automated processes.
Business Rules Engine	System that processes predefined rules to make automated decisions.

LAB NOTES — Week 5: Phase 04 & Phase 05 — ITSM Integration Lab

"Detection without systematic response is just noise. Service Management turns alerts into action." — Phase 04 Core Principle

PHASE 04

Service Management — Lab Notes

SLAs · Severity · Ticket Workflow · Metrics

Connecting the Dots — Process Cycle Phases

Phase	Activity	When
Phase 01–02	Logs collected and normalised	Week 3
Phase 03	Correlation generates alerts	Week 4
Phase 04 ← YOU ARE HERE	Service Management tracks incidents	Week 5
Phase 05 ← YOU JUST BUILT THIS	Workflow Automation orchestrates it all	Week 5
Phase 06–07	Incident Response and Remediation	Coming next

Understanding SLAs

SLA = Service Level Agreement: documented commitments for response times based on severity.

SLA Response Times Configuration

Severity	Response Time	Assigned Team
CRITICAL	15 minutes	Incident Response
HIGH	1 hour	Security Operations Centre
MEDIUM	4 hours	Network Security
LOW	8 hours	IT Support

Why SLAs Matter

- Critical incidents need immediate attention (15 min)
- Teams know their response obligations
- Management can track SLA compliance
- Prevents incidents from being forgotten

Q: If an alert has 12 failed login attempts at 3:00 AM, what severity and SLA would it receive?

A: CRITICAL severity, 15 minute SLA — high event count ($12 \geq 10 \rightarrow$ CRITICAL) escalated further due to off-hours timing.

Severity Calculation Logic

Severity is not fixed — it is calculated based on multiple factors. The algorithm runs 4 steps in sequence to determine the final severity of any alert.

The 4-Step Severity Algorithm

Step	Check	Rules
Step 1	Start with baseline severity	Use the severity value already in the alert as the starting point
Step 2	Check event count	10+ events → CRITICAL 5–9 events → HIGH 3–4 events → MEDIUM <3 events → LOW
Step 3	Check timing (off-hours escalation)	Off-hours (before 9 AM or after 5 PM): MEDIUM → HIGH, LOW → MEDIUM Business hours (9 AM–5 PM): No change
Step 4	Check whitelist	Known-good IP (monitoring server, backup system) → Downgrade to LOW regardless of event count

■ **Important:** Whitelisted IPs are ALWAYS downgraded to LOW, even with high event counts. These are known-good sources performing legitimate tasks (e.g. monitoring servers, backup systems).

Worked Example

Alert: 6 failed logins from 192.168.1.100 at 09:15 AM

Step	Check	Result
Step 1	Baseline severity from alert	HIGH
Step 2	Event count = 6	6 is in the 5–9 range → HIGH (no change)
Step 3	Time = 09:15 AM	Business hours → no change
Step 4	IP = 192.168.1.100	Not whitelisted → no change
FINAL	Final Severity	HIGH → Team: Security Operations Centre → SLA: 1 hour

Q: What is the purpose of the whitelist check in severity calculation?

A: To acknowledge known-good sources that generate expected activity — so monitoring servers and backup systems don't flood the SOC with false positives.

Lab Code — Part 1: Core Functions

The lab implements the Alert-to-Ticket workflow in Python. Understanding each function explains exactly how the theory maps to real automation code.

Function 1: is_business_hours() — Check if alert occurred 9 AM–5 PM

```
def is_business_hours(timestamp_str):
    try:
        dt = datetime.fromisoformat(timestamp_str)
        return BUSINESS_HOURS['start'] <= dt.hour < BUSINESS_HOURS['end']
```

```
except:
    return True # Default to business hours if parse fails
```

Function 2: calculate_severity() — Apply the 4-step algorithm

```
def calculate_severity(alert):
    severity = alert.get('severity', 'MEDIUM')

    # Step 2: Check event count
    event_count = alert.get('event_count', 0)
    if event_count >= 10:
        severity = 'CRITICAL'
    elif event_count >= 5 and severity not in ['CRITICAL']:
        severity = 'HIGH'

    # Step 3: Escalate if off-hours
    if not is_business_hours(alert['timestamp']):
        if severity == 'MEDIUM':
            severity = 'HIGH'
        elif severity == 'LOW':
            severity = 'MEDIUM'

    # Step 4: Downgrade if whitelisted
    if alert.get('source_ip') in WHITELIST:
        severity = 'LOW'

    return severity
```

Code Breakdown: The severity calculation implements **decision support** — automated logic that helps analysts prioritise their work without requiring manual assessment of every alert.

Lab Code — Part 2: Ticket Creation & Metrics

Function 3: get_sla_details() — Look up SLA configuration

```
def get_sla_details(severity):
    return SLA_RULES.get(severity, SLA_RULES['MEDIUM'])
```

Function 4: calculate_sla_deadline() — Add response time to creation timestamp

```
def calculate_sla_deadline(created_at, response_time_minutes):
    return created_at + timedelta(minutes=response_time_minutes)
```

Function 5: create_ticket() — Build the complete ticket structure

```
def create_ticket(alert):
    created_at = datetime.now()
    severity = calculate_severity(alert)
    sla_info = get_sla_details(severity)
    sla_deadline = calculate_sla_deadline(created_at, sla_info['response_time_minutes'])
```

```

ticket = {
    'ticket_id': f"TKT-{alert['alert_id']}",
    'title': f"{alert['alert_type']}: {alert['source_ip']}",
    'severity': severity,
    'priority': sla_info['priority'],
    'assigned_team': sla_info['assigned_team'],
    'team_contact': TEAM_CONTACTS.get(sla_info['assigned_team'], {}),
    'status': 'Open',
    'created_at': created_at.isoformat(),
    'sla_deadline': sla_deadline.isoformat(),
    'sla_response_time_minutes': sla_info['response_time_minutes'],
    'escalation_required': sla_info['escalation_required'],
    'source_alert': alert
}
return ticket

```

Function 6: generate_tickets() — Process all alerts into tickets

```

generate_tickets(alerts):
    ticket = create_ticket(alert) # update variable inside the loop

```

Function 7: calculate_metrics() — Calculate all service management KPIs

```

def calculate_metrics(tickets):
    from collections import Counter
    if not tickets:
        return {'total_tickets': 0, 'by_severity': {}, 'by_team': {},
                'average_sla_minutes': 0, 'escalation_rate': 0}

    severities = [t['severity'] for t in tickets]
    teams = [t['assigned_team'] for t in tickets]
    sla_times = [t['sla_response_time_minutes'] for t in tickets]
    escalations = sum(1 for t in tickets if t['escalation_required'])

    metrics = {
        'total_tickets': len(tickets),
        'by_severity': dict(Counter(severities)),
        'by_team': dict(Counter(teams)),
        'average_sla_minutes': sum(sla_times)/len(sla_times) if sla_times else 0,
        'escalation_rate': (escalations/len(tickets))*100 if tickets else 0
    }
    return metrics

```

Understanding the Metrics

The workflow calculates key service management KPIs automatically.

1. Tickets by Severity — Incident distribution, helps capacity planning

Pattern	What It Means
Too many CRITICAL?	May need tighter security controls
Mostly LOW?	Alert tuning working well
Balanced distribution?	Indicates realistic threat landscape

2. Tickets by Team — Workload distribution

Team	Handles	Mode
Incident Response	CRITICAL	Immediate action
Security Operations Centre (SOC)	HIGH	Active monitoring
Network Security	MEDIUM	Scheduled investigation
IT Support	LOW	Routine follow-up

3. Average SLA Response Time

Weighted average across all tickets — indicates the overall urgency level of the incident workload.

4. Escalation Rate

Percentage of tickets requiring management notification — tracks incident severity trends over time.

Why These Metrics Matter — Business Value

Metric	Business Value
MTTR (Mean Time to Respond/Resolve)	Faster response = less damage from attacks
SLA Compliance	Demonstrates consistent service delivery
Team Distribution	Ensures no team is overwhelmed
Escalation Rate	Tracks severity trends over time

Q: If your escalation rate suddenly increases from 10% to 40%, what might this indicate?

A: More CRITICAL incidents are occurring, possibly indicating increased threat activity — not that automation is more efficient or that response is faster.

Expected Lab Output — Test Your Workflow

Running `python scripts/itsm_starter.py` inside the container should produce:

```
=====
WEEK 5 LAB: ITSM INTEGRATION - ALERT TO TICKET
=====

[+] Loaded 6 alerts from data/alerts.json
=====
```

```
GENERATING SERVICE DESK TICKETS
=====

Processing alert 1/6: BF-20260213-1921681100
✓ Created ticket: TKT-BF-20260213-1921681100
Severity: HIGH
Team: Security Operations Centre
SLA: 60 minutes

[... 5 more tickets ...]

=====

SERVICE MANAGEMENT METRICS
=====

Total Tickets Created: 6
Tickets by Severity:
CRITICAL: 2
HIGH: 3
MEDIUM: 1

Tickets by Team:
Incident Response: 2
Network Security: 1
Security Operations Centre: 3

Average SLA Response Time: 75 minutes
Escalation Rate: 33.3%

[✓] Tickets saved to outputs/tickets.json
```

Success Indicator: You should have 6 tickets with different severities and teams. Notice how the off-hours alert (03:15 AM) was escalated to CRITICAL!

Q: What does MTTR (Mean Time to Respond) measure in this context?

A: The total time a ticket remains open from creation to closure.

Connect to Your Projects — How This Maps to Real Tools

What you just built bridges **Phase 03 (SOC)** and **Phase 04 (Service Management)**. Your Python workflow demonstrates the logic that enterprise ITSM platforms implement at scale.

Week 4 flow:	Detection → Correlation → Alert
Week 5 flow:	Alert → Ticket → Team → SLA → Tracking

How This Maps to Your Project Tools

Project	How Week 5 Concepts Apply
Data Engineering (ELK)	Kibana Detection Rules → Actions → Webhook to ServiceNow/Jira API. Your create_ticket() logic = their create_ticket()

Security Monitoring (Graylog)	Event Definitions → Notifications → HTTP Output. Your severity calculation = their priority mapping in no
Security Monitoring (Security Onion)	Suricata/Zeek alerts → TheHive integration. Alerts become Cases with SLA timers. Your ticket structure
Incident Response (TheHive)	Your tickets = TheHive Cases. Your SLA = their custom fields + dashboard timers. MSP integration che
Security Assessment (Wazuh)	Wazuh alerts → Integration module → External ticket system. Your workflow = their Integrator daemon c
Systems Maintenance (Ansible)	Playbooks automate: Create ticket → Execute remediation → Update ticket status → Close when resolv

■ **This lab is conceptual.** It teaches you the logic behind alert-to-ticket workflows. For your competency project, you must check the project requirements and research how (and whether) service-management steps are implemented in your specific tool. Each platform handles integration differently.

Q: What is the key benefit of automating the alert-to-ticket workflow?

A: It ensures systematic tracking and accountability for every security alert without manual data entry — not to eliminate analysts, prevent all incidents, or make correlation rules unnecessary.

PHASE

06

Incident Response

Detect · Contain · Eradicate · Recover · Learn

NIST RESPOND

Feeds into → Phase 07
(Remediation)

Phase 06 Overview

Phase 06 — Incident Response — is the structured process of identifying, containing, eradicating and recovering from a security incident. It is the phase where everything that was detected and tracked in Phases 03, 04 and 05 gets actively dealt with. While Phase 04 created the ticket and Phase 05 automated the routing, Phase 06 is where the actual security work happens — analysts investigate, contain the threat, remove it from the environment, and restore normal operations.

"Phase 04 tracks the incident. Phase 05 automates the workflow. Phase 06 actually fixes the problem."

Where Phase 06 Sits in the Process Cycle

Phase	Activity	Role in IR
Phase 03 — SOC & SIEM	Detects the threat	Provides the evidence and alert
Phase 04 — Service Management	Creates and tracks the ticket	Defines the SLA and team
Phase 05 — Workflow Automation	Automates the routing	Kicks off the IR playbook
Phase 06 — Incident Response	Actively responds to the threat	PRIMARY — contains, eradicates, recovers
Phase 07 — Remediation	Fixes the root cause permanently	Follows on from Phase 06

NIST RESPOND Framework

Phase 06 maps to the NIST RESPOND function. NIST RESPOND defines the activities an organisation takes once a security event has been confirmed. It ensures that the response is coordinated, documented, and effective.

NIST Category	What It Means	Phase 06 Activity
Response Planning	Having a plan ready before incidents happen	Incident response playbooks, runbooks, and procedures defined in advance
Communications	Keeping the right people informed during an incident	Notification management, legal, affected users, and external parties if needed
Analysis	Understanding what happened and how serious it is	Source investigation, scope assessment, impact analysis
Mitigation	Limiting the damage while the incident is ongoing	Containment actions — isolating systems, blocking IPs, revoking credentials
Improvements	Learning from the incident to prevent recurrence	Post-incident review, lessons learned, updating playbooks and controls

The Incident Response Lifecycle — 6 Phases

The industry standard IR lifecycle consists of 6 phases, often called PICERL. Every security incident — from a single compromised account to a full network breach — follows this same structure.

1

PREPARATION

- Build and maintain the IR capability before incidents happen
- Write playbooks and runbooks for known attack scenarios
- Train the IR team and conduct tabletop exercises
- Deploy and configure tools: SIEM, SOAR, forensic tools
- Establish communication plans and escalation paths
- Define roles and responsibilities for the IR team

2

IDENTIFICATION

- Confirm whether an alert is a genuine security incident
- Triage the alert — true positive or false positive?
- Determine the scope — what systems and data are affected?
- Classify the incident type (malware, data breach, insider threat, etc.)
- Assign severity level and trigger the appropriate playbook
- Sources: SIEM alerts, Phase 04 tickets, user reports, threat intelligence

3

CONTAINMENT

- Stop the incident from spreading further — this is the immediate priority
- Short-term containment: isolate affected systems from the network
- Long-term containment: patch vulnerabilities, reset credentials
- Preserve evidence — do NOT wipe systems before forensic imaging
- Block malicious IPs at the firewall
- Revoke compromised user accounts and access tokens

4

ERADICATION

- Remove the threat completely from the environment
- Delete malware, backdoors, and malicious files
- Remove unauthorised user accounts created by the attacker
- Identify and patch the root cause vulnerability
- Scan all systems to confirm the threat has been fully removed
- Validate that no persistence mechanisms remain

5

RECOVERY

- Restore affected systems and services to normal operation
- Restore from clean backups where systems were compromised
- Rebuild systems from scratch if integrity cannot be verified
- Monitor restored systems closely for signs of reinfection
- Gradually restore services — do not rush back to full operation
- Confirm with business stakeholders that services are functioning correctly

6

LESSONS LEARNED

- Review the entire incident from detection to resolution
- What went well? What could have been faster or better?
- Update playbooks based on what was discovered
- Add new IOCs to threat intelligence (MISP)
- Improve detection rules in the SIEM to catch it earlier next time
- Document everything — timeline, actions taken, outcomes

Key Memory Aid — PICERL: Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned

Knowledge Check: What is the most important rule during the Containment phase?

✓ **Answer:** Preserve evidence — do NOT wipe or reimage systems before taking a forensic image. Destroying evidence makes investigation and legal action impossible.

Containment Strategies

Containment is split into two types. Both happen during Phase 3 (Containment) of PICERL but serve different purposes.

Type	When	Actions	Goal
Short-Term Containment	Immediately — within minutes	Isolate system from network, block IP at firewall, disable user account	Stop the bad thing — prevent spread right now
Long-Term Containment	After immediate threat is stopped	Apply patches, rebuild systems, reset all credentials, segment network	Make this segment safe enough to continue work

Containment Decision Factors

Before isolating a system, consider:

- Business impact — will isolating this system stop critical operations?
- Evidence preservation — is the system needed for forensic investigation?
- Attacker awareness — will containment alert the attacker and cause them to escalate?
- Scope — are there other systems already compromised that also need isolating?

Types of Security Incidents

Phase 06 handles many different types of incidents. Each has its own playbook.

Incident Type	Description	Key Containment Action
Malware / Ransomware	Malicious software installed on systems. Ransomware encrypts files and demands payment.	Isolate infected systems immediately. Do NOT pay ransom. Restore from backups.
Phishing Attack	Deceptive email tricks user into revealing credentials or installing malware.	Reset compromised credentials. Block malicious domains. Scan for malware.
Brute Force / Credential Attack	Repeated login attempts to gain unauthorised access.	Block source IP. Lock targeted accounts. Enable MFA.
Insider Threat	Malicious or negligent action by an employee or contractor.	Revoke access immediately. Preserve logs. Involve HR and legal.
Data Breach	Unauthorised access to or exfiltration of sensitive data.	Identify what data was accessed. Notify affected parties. Preserve evidence.
DDoS Attack	Flooding a service with traffic to make it unavailable.	Activate DDoS mitigation. Rate limit traffic. Contact ISP if needed.
SQL Injection	Malicious database queries injected through a web application.	Block attacking IP. Patch the vulnerable application. Review database logs.
Unauthorised Access	Someone accessing systems or data they are not permitted to access.	Revoke access. Review access logs. Identify what was accessed or modified.

Incident Response Team — Roles and Responsibilities

Role	Responsibilities
Incident Commander / IR Lead	Oversees the entire response. Makes key decisions. Coordinates all team members. Communicates with management.
SOC Analyst	First responder. Triage alerts from SIEM. Confirms true/false positive. Gathers initial evidence. Escalates to IR team.
Forensic Analyst	Collects and preserves digital evidence. Performs memory and disk forensics. Analyses malware samples.
Threat Intelligence Analyst	Identifies attacker tools, tactics and procedures (TTPs). Cross references IOCs with threat intelligence feeds.
Network Security Engineer	Implements network-level containment (firewall blocks, network isolation). Analyses network traffic. Identifies compromised hosts.
Systems Administrator	Assists with system isolation, rebuilds, and restoration. Applies patches. Restores from backups. Validates system integrity.

Communications / Management	Handles internal and external communications. Notifies affected stakeholders. Manages legal and regulatory requirements.
Legal / Compliance	Advises on legal obligations. Manages regulatory notifications (e.g. GDPR 72-hour breach notification requirements).

Incident Severity Classification

Not all incidents are equal. Severity classification determines how quickly the IR team responds and what resources are deployed.

Level	Criteria	Response Time	Team	Example
P1 CRITICAL	Active breach. Data being exfiltrated. Core systems down.	15 minutes	Full IR team + management	Ransomware spreading across network
P2 HIGH	Confirmed compromise. Contained but threat still present.	1 hour	IR team + SOC	Compromised admin account detected
P3 MEDIUM	Suspicious activity. Potential compromise. Under investigation.	4 hours	SOC analyst	Unusual login pattern from known user
P4 LOW	Policy violation. Low risk activity. No confirmed compromise.	8 hours	IT Support	User accessing restricted website

Digital Forensics and Evidence Collection

Forensics is the process of collecting, preserving and analysing digital evidence during an incident. Evidence must be collected in a way that maintains its integrity — otherwise it cannot be used for legal proceedings or accurate investigation.

Order of Volatility — Collect in This Order

Volatile data disappears when a system is powered off. Always collect the most volatile data first.

Priority	Data Type	Why It Disappears	How to Collect
1 — Most Volatile	CPU registers and cache	Gone instantly when powered off	Memory forensic tool (Volatility)
2	RAM / Memory contents	Lost on reboot or shutdown	Memory dump (Volatility, WinPmem)
3	Running processes	Changes constantly	Process listing (ps, tasklist)
4	Network connections	Active sessions change rapidly	netstat, network capture (Wireshark)
5	Open files and handles	Change as system operates	lsif, handle.exe
6	Disk / filesystem	Relatively stable but can be modified	Disk image (dd, FTK Imager)
7 — Least Volatile	Log files and archives	Stable but may be rotated/deleted	Copy logs to secure location

Chain of Custody

Every piece of evidence must have a documented chain of custody — a record of who collected it, when, how, and who has handled it since. Without this, evidence may be inadmissible in legal proceedings.

- Record the date, time, and location evidence was collected
- Document who collected it and what method was used
- Hash every evidence file (MD5, SHA-256) immediately after collection — this proves it has not been tampered with
- Store evidence in a secure, tamper-evident location
- Record every person who accesses the evidence and when
- Never work directly on original evidence — always work on a forensic copy

Knowledge Check: Why do you hash evidence immediately after collection?

✓ **Answer:** Hashing creates a unique digital fingerprint of the file at the time of collection. If the hash matches later, it proves the evidence has not been modified. This is essential for maintaining evidence integrity in legal proceedings.

Worked Example — Brute Force to Breach

Following on from the example used in Phase 03 and Phase 04. IP 192.168.1.100 triggered a brute force alert. The SOC confirmed it as a true positive. Here is how Phase 06 handles it through PICERL.

P

PREPARATION (already done)

Brute force playbook already exists from preparation phase
SIEM correlation rule already configured (5+ failed logins in 120 seconds)
IR team contacts and escalation paths already defined
Firewall API access already configured for automated blocking

I

IDENTIFICATION

SIEM alert fires: BF-20260213-1921681100 — 6 failed SSH logins from 192.168.1.100
Phase 04 ticket created: TKT-BF-20260213-1921681100, severity HIGH, SLA 60 min
SOC analyst checks logs — confirms external IP, targeting admin accounts
Checks for successful login after failures — FOUND: successful_login at 09:16:42
CONFIRMED: True positive — attacker got in. Escalate to P1 CRITICAL

C

CONTAINMENT

Short-term: Block 192.168.1.100 at firewall immediately
Short-term: Disable compromised admin account
Short-term: Isolate affected server from network
Take forensic memory dump of affected server before any changes
Long-term: Force password reset for all admin accounts
Long-term: Review and restrict SSH access rules

E

ERADICATION

Forensic analyst examines memory dump for malware or backdoors
Check for new user accounts created by attacker
Check for scheduled tasks, startup items, or persistence mechanisms
Scan all systems for lateral movement — did attacker reach other systems?
Remove any malicious files, accounts, or configurations found
Patch the SSH vulnerability that allowed the brute force to succeed

R

RECOVERY

Rebuild server from clean backup taken before the compromise
Verify integrity of restored system — hash comparison with known-good baseline
Re-enable server with hardened configuration (MFA on SSH, rate limiting)
Monitor server closely for 72 hours post-restoration
Gradually restore normal operations — confirm with system owner

L

LESSONS LEARNED

Why did brute force succeed? — SSH had no rate limiting or account lockout
Why did attacker get in? — Admin account had weak password
Update SIEM rule to alert earlier (3 failures instead of 5)
Add 192.168.1.100 and related IPs to threat intelligence (MISP)
Enforce MFA on all admin SSH access going forward
Update brute force playbook with account lockout as immediate step

Incident Response Playbooks

A playbook is a predefined set of steps for responding to a specific type of incident. Playbooks ensure that every analyst follows the same process every time, regardless of experience level or time pressure. In Phase 05, playbooks are automated via SOAR. In Phase 06, they guide the actual response actions.

Playbook vs Runbook — Key Distinction

	Playbook	Runbook
Definition	High-level strategic steps for responding to a specific incident type	Detailed technical instructions for completing a specific task
Who uses it	IR team — guides decision making during an incident	Sysadmin / engineer — step by step technical execution
Automation	Can be automated in SOAR (Phase 05)	Can be partially automated but often requires human action
Example	"Brute Force Response Playbook" — isolate, block, investigate, take over	"Isolate, take over forensic disk image using FTK Imager"

Example Playbook Structure — Phishing Response

1	TRIAGE Confirm the phishing email is genuine — check headers, links, sender Identify all recipients of the phishing email Determine if any user clicked the link or opened the attachment
2	CONTAINMENT Block the malicious URL/domain at the web proxy and firewall Quarantine the phishing email from all mailboxes Isolate any machines where the attachment was opened
3	INVESTIGATION Check if credentials were entered on the phishing page Scan isolated machines for malware Review email gateway logs for similar emails
4	ERADICATION Reset credentials for any accounts that may be compromised Remove malware from affected machines Delete phishing emails from all mailboxes
5	RECOVERY Restore affected machines from clean backup if needed Re-enable user accounts with new strong credentials and MFA Confirm with users that systems are working correctly
6	NOTIFICATION Notify affected users about the phishing attempt Report to management and compliance team Submit phishing indicators to threat intelligence feeds

Incident Response Tools

Case Management & Orchestration

Tool	Type	Key Use in IR
TheHive	Open Source Case Management	Creates and manages IR cases. Links alerts from SIEM. Tracks tasks and timelines. Integrates with other tools.
Splunk SOAR (Phantom)	Enterprise SOAR	Automates IR playbooks. Orchestrates tools. Reduces manual steps in containment.
IBM Security SOAR	Enterprise SOAR	Dynamic playbooks. Case management. Threat intelligence integration.
ServiceNow SecOps	ITSM + IR	Manages IR tickets with SLA tracking. Links Phase 04 and Phase 06 together.

Forensics Tools

Tool	Purpose	What It Does
Volatility	Memory Forensics	Analyses RAM dumps. Finds running processes, network connections, injected malware, and more.
Autopsy / Sleuth Kit	Disk Forensics	Analyses disk images. Recovers deleted files. Examines file system artefacts. Builds file timelines.
FTK Imager	Evidence Collection	Creates forensic disk images. Preserves evidence without modifying the original. Generates hash values.
Wireshark	Network Forensics	Captures and analyses network traffic. Identifies C2 communications, data exfiltration, and lateral movement.
MISP	Threat Intelligence	Stores and shares IOCs (IP addresses, file hashes, domain names). Correlates incident indicators.
Velociraptor	Endpoint Forensics	Live response and hunting across multiple endpoints simultaneously. Collects artefacts at scale.

Detection and Analysis Tools

Tool	Purpose	IR Use
ELK Stack / Splunk	SIEM / Log Analysis	Search logs during investigation. Build incident timelines. Identify scope of compromise.
Wazuh	EDR / HIDS	Host-based detection. File integrity monitoring. Detects suspicious processes and configuration changes.
Security Onion	Network Monitoring	Network traffic analysis. Zeek logs for connection analysis. Suricata alerts for network-based attacks.
YARA	Malware Detection	Rule-based scanning to identify malware by patterns in files. Used to scan systems for known malware.
Nmap	Network Scanning	Maps network topology during investigation. Identifies unexpected open ports or new systems.

Communications During an Incident

Communication is one of the most critical and often most poorly handled parts of incident response. The wrong communication at the wrong time can make an incident significantly worse.

Internal Communications

- IR team communicates on a dedicated secure channel — not normal email (attacker may have email access)
- Incident Commander provides regular status updates to management
- Only share information on a need-to-know basis — do not broadcast details widely
- Document all decisions and actions in the case management system (TheHive)
- Use out-of-band communication if normal systems are compromised (phone, Signal)

External Communications

Audience	Guidance
Affected Users	Notify only when you have confirmed facts. Avoid panic. Provide clear guidance on what they should do.
Regulators	GDPR requires notification within 72 hours of a personal data breach. Other regulations have similar requirements.
Law Enforcement	Contact if criminal activity is involved (e.g. ransomware, nation-state attack, data theft for sale).
Media / Press	Only through authorised spokesperson. Coordinate with legal team. Do not confirm details until ready.
Third Parties	Notify affected partners, suppliers, or customers if their data or systems are involved.

■ **GDPR Note:** If personal data is involved in a breach, organisations have a legal obligation to notify the relevant supervisory authority (e.g. ICO in the UK) within **72 hours** of becoming aware of the breach. Failure to notify can result in significant fines.

Incident Response Metrics

Metrics measure how effective the IR process is and identify areas for improvement.

Metric	Full Name	Definition	Why It Matters
MTTD	Mean Time to Detect	Average time between incident start and detection	Shorter = attacker has less time in the environment
MTTC	Mean Time to Contain	Average time from detection to containment	Shorter = less damage and spread
MTTR	Mean Time to Respond / Resolve	Average time from detection to full resolution	Key SLA metric from Phase 04
MTTI	Mean Time to Investigate	Average time spent investigating each incident	Tracks analyst efficiency and workload
SLA Compliance Rate		Percentage of incidents handled within defined SLA	Ensures consistent service delivery
Escalation Rate		Percentage of incidents escalated to higher severity	Higher increase may indicate a major attack campaign
False Positive Rate		Percentage of alerts that turn out to be false positives	High rate indicates poor SIEM tuning — alert fatigue risk
Containment Rate		Percentage of incidents contained without data loss or effective damage	Measures effectiveness of containment procedures

Knowledge Check: What is the difference between MTTD and MTTR?

✓ **Answer:** MTTD (Mean Time to Detect) measures how long before the incident was found. MTTR (Mean Time to Resolve) measures from detection all the way to full resolution. MTTD is about detection speed. MTTR is about the entire response process.

Code Concepts — IR Automation

Just as Phase 04 and 05 used Python to automate ticket creation, Phase 06 automation focuses on containment actions and evidence collection. Here are the key code concepts used in IR automation.

Automated Containment — Blocking an IP via Firewall API

```
def contain_threat(alert):
    """Automated containment triggered by confirmed incident"""
    actions_taken = []

    # Step 1: Block attacking IP at firewall
    if alert.get("source_ip"):
        firewall_block(alert["source_ip"])
        actions_taken.append(f"Blocked IP: {alert['source_ip']}")

    # Step 2: Disable compromised user account
    if alert.get("username"):
        disable_account(alert["username"])
        actions_taken.append(f"Disabled account: {alert['username']}")

    # Step 3: Isolate affected system
    if alert.get("system_name"):
        isolate_system(alert["system_name"])
        actions_taken.append(f"Isolated system: {alert['system_name']}")

    # Step 4: Update ticket status
    update_ticket(alert["ticket_id"], status="Contained",
        notes=actions_taken)

    return actions_taken
```

Evidence Collection — Preserving Logs

```
import hashlib, json
from datetime import datetime

def collect_evidence(incident_id, log_data):
    """Preserve logs with hash for integrity verification"""

    evidence = {
        "incident_id": incident_id,
        "collected_at": datetime.now().isoformat(),
        "collector": "IR_Automation_System",
        "data": log_data
    }
```

```

# Serialise to JSON string
evidence_str = json.dumps(evidence, sort_keys=True)

# Generate SHA-256 hash for integrity verification
evidence_hash = hashlib.sha256(
evidence_str.encode()).hexdigest()

return {
"evidence": evidence,
"sha256_hash": evidence_hash,
"chain_of_custody": f"Collected by IR system at {evidence['collected_at']}"
}

```

Post-Incident Timeline Builder

```

def build_incident_timeline(case_id, siem_logs):
    """Build chronological timeline from SIEM logs for lessons learned"""

    timeline = []
    for event in sorted(siem_logs, key=lambda x: x["normalised_timestamp"]):
        timeline.append({
            "time": event["normalised_timestamp"],
            "source": event["source_type"],
            "event": event["event_type"],
            "severity": event["severity"],
            "detail": event.get("raw_message", "")
        })

    report = {
        "case_id": case_id,
        "generated": datetime.now().isoformat(),
        "event_count": len(timeline),
        "timeline": timeline
    }

    return report

```

Code Breakdown: These three functions represent the three core automation tasks in Phase 06 — **containment** (stop the threat), **evidence collection** (preserve proof), and **timeline building** (understand what happened). In a real SOAR platform like TheHive or Splunk Phantom, these functions are wrapped into automated playbooks that execute the moment an incident is confirmed.

How Phase 06 Maps to Your Project Tools

Project	How Phase 06 Concepts Apply
Data Engineering (ELK)	ELK provides the forensic log search during investigation. Kibana timelines reconstruct the attack. Elasticsearch provides the data source.
Security Monitoring (Graylog)	Graylog alerts trigger the IR process. Stream rules escalate confirmed incidents. Dashboard shows incident details.
Security Monitoring (Security Zeek logs)	Zeek logs provide network forensics. Suricata alerts identify attack type. PCAP files provide packet-level evidence.
Incident Response (TheHive)	TheHive IS the Phase 06 case management system. Cases = incidents. Tasks = PICERL steps. Observables = indicators of compromise.
Security Assessment (Wazuh)	Wazuh active response automatically blocks IPs and isolates endpoints. File integrity monitoring detects persistence.
Systems Maintenance (Ansible)	Ansible playbooks automate containment (firewall rules, account disabling), eradication (removing malware), and recovery (restoring systems).

Knowledge Checks

Knowledge Check: What does PICERL stand for?

✓ **Answer:** Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned — the 6 phases of the incident response lifecycle.

Knowledge Check: Why must you preserve evidence before containing a threat?

✓ **Answer:** Forensic evidence (memory dumps, logs, disk images) can be destroyed during containment actions. You must image systems before wiping or rebuilding them, otherwise you lose the ability to investigate what happened and cannot support legal proceedings.

Knowledge Check: What is the difference between containment and eradication?

✓ **Answer:** Containment stops the threat from spreading further — it is immediate damage limitation. Eradication completely removes the threat from the environment. You contain first, then eradicate once it is safe to do so.

Knowledge Check: A ransomware attack is detected at 2 AM encrypting files. What is the first action?

✓ **Answer:** Immediately isolate the affected systems from the network to prevent the ransomware spreading to other machines. Do NOT shut down the system yet — take a memory dump first to preserve evidence of the encryption keys which may be in RAM.

Knowledge Check: What is the GDPR requirement for data breaches?

✓ **Answer:** Organisations must notify the relevant supervisory authority within 72 hours of becoming aware of a personal data breach. If affected individuals are at high risk, they must also be notified directly without undue delay.

Knowledge Check: Why do you work from a forensic copy rather than the original evidence?

✓ **Answer:** Working on the original could modify it — file access timestamps change, data could be accidentally altered. A forensic copy preserves the original exactly. The hash of the copy should match the original to prove integrity.

Phase 06 — Full Terminology Glossary

Term	Definition
Incident Response (IR)	The organised approach to addressing and managing the aftermath of a security breach or cyberattack. The goal is to handle the situation in a way that limits damage and reduces recovery time and costs.
PICERL	The six-phase incident response lifecycle: Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned.
NIST RESPOND	The NIST Cybersecurity Framework function covering activities taken once a cybersecurity incident has been detected. Includes response planning, communications, analysis, mitigation, and improvements.
Preparation	The phase of IR that happens before any incident occurs. Includes writing playbooks, training staff, configuring tools, and establishing communication plans.
Identification	The phase where an alert is triaged to confirm whether it is a genuine security incident, determine its scope and severity, and classify the incident type.
Containment	The phase where the IR team prevents the incident from spreading further. Split into short-term (immediate isolation) and long-term (hardening) containment.
Eradication	The phase where the threat is completely removed from the environment — deleting malware, removing backdoors, patching vulnerabilities, and eliminating attacker persistence.
Recovery	The phase where affected systems are restored to normal operation. Includes restoring from backups, rebuilding systems, and monitoring for signs of reinfection.
Lessons Learned	The final phase where the team reviews the entire incident to identify what went well, what could be improved, and how to prevent recurrence.
Playbook	A predefined set of response steps for a specific type of security incident. Ensures consistent, structured response regardless of who is responding.
Runbook	Detailed technical step-by-step instructions for completing a specific IR task. More technical than a playbook, designed for execution by engineers.
Tabletop Exercise	A simulated incident response exercise where the IR team talks through their response to a hypothetical scenario. Used to test readiness without real systems.
Forensics / Digital Forensics	The process of collecting, preserving, and analysing digital evidence from computers, networks, and storage devices in a way that maintains integrity.
Order of Volatility	The principle that forensic evidence should be collected from most volatile (disappears fastest) to least volatile. RAM is collected before disk, which is collected before logs.
Chain of Custody	A documented record of who collected evidence, when, how, and everyone who has handled it. Essential for maintaining evidence integrity and admissibility in legal proceedings.
Forensic Image	A bit-for-bit copy of a storage device that captures everything including deleted files and unallocated space. Created without modifying the original.
Hash / Checksum	A unique digital fingerprint of a file generated by algorithms like MD5 or SHA-256. Used to verify that evidence has not been tampered with.
IOC — Indicator of Compromise	Forensic evidence suggesting a system has been compromised. Examples: known malicious IP addresses, file hashes of malware, suspicious domain names.

TTP — Tactics, Techniques and Procedures	The behaviour patterns and methods used by threat actors. Understanding TTPs helps predict attacker actions and improve detection.
Lateral Movement	When an attacker moves from one compromised system to other systems within the network to expand their access and reach their target.
Persistence	Techniques used by attackers to maintain access to a compromised system even after reboots or credential changes. Examples: scheduled tasks, startup scripts, backdoors.
Exfiltration	The unauthorised transfer of data from a system or network to an external location controlled by the attacker.
C2 / Command and Control	Infrastructure used by attackers to communicate with and control compromised systems. Identifying C2 traffic is a key investigation priority.
MISP	Malware Information Sharing Platform — an open source threat intelligence platform for sharing IOCs between organisations and IR teams.
TheHive	Open source security incident response platform used for case management, task tracking, and evidence collection during IR.
Volatility	Open source memory forensics framework used to analyse RAM dumps. Can extract running processes, network connections, injected code, and encryption keys from memory.
Wireshark	Network protocol analyser used to capture and examine network traffic. Used in IR to identify C2 communications and data exfiltration.
Triage	The process of quickly assessing multiple alerts or incidents to prioritise which require immediate attention.
Scope Assessment	Determining the full extent of a security incident — which systems were affected, what data was accessed, and how far the attacker penetrated.
Post-Incident Review	A structured review of the entire incident conducted after resolution. Produces lessons learned and recommendations for improving the IR process.
MTTD	Mean Time to Detect — average time between the start of an incident and its detection by the security team.
MTTC	Mean Time to Contain — average time from detection to successful containment of the incident.
MTTR	Mean Time to Resolve — average time from detection to full resolution and closure of the incident.
False Positive	An alert that upon investigation turns out to be benign activity, not a real security incident.
True Positive	An alert that correctly identifies a genuine security incident requiring response.
GDPR	General Data Protection Regulation — EU/UK law requiring organisations to report personal data breaches to regulators within 72 hours.
Incident Commander	The person who leads and coordinates the incident response. Makes key decisions, manages communications, and oversees the entire response.

Phase 06 — Quick Reference Card

Concept	Key Point
IR Lifecycle	PICERL: Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned
NIST Mapping	NIST RESPOND

First action on confirmed incident	Contain — stop it spreading. But preserve evidence first.
Order of Volatility	RAM → Processes → Network connections → Disk → Logs
Evidence integrity	Hash immediately with SHA-256. Never work on originals.
GDPR breach notification	72 hours to notify supervisory authority
Short-term containment	Isolate system, block IP, disable account
Long-term containment	Patch, rebuild, reset all credentials
MTTD	Mean Time to Detect — how long before incident was found
MTTC	Mean Time to Contain — how fast it was stopped from spreading
MTTR	Mean Time to Resolve — full resolution time
Key IR tool	TheHive — case management, tasks, evidence, MISP integration
Key forensics tool	Volatility — memory forensics, Wireshark — network forensics
Feeds into	Phase 07 — Remediation (permanent fixes)

PHASE
07

Remediation, Recovery & Resilience

Remediate · Recover · Rebuild · Prevent Recurrence

NIST RECOVER

Culmination of the full Cyber Security Operations Process Cycle — feeds back to Phase 01

Phase 07 Overview

Phase 07 — Remediation, Recovery and Resilience — represents the culmination of the Cyber Security Operations Process Cycle. It is the phase that comes after Phase 06 (Incident Response) has contained and eradicated the immediate threat. Where Phase 06 focuses on stopping the damage and removing the attacker, Phase 07 focuses on three things: permanently fixing what was broken, restoring everything to full working order, and making the organisation stronger so the same thing cannot happen again.

"Phase 06 stops the bleeding. Phase 07 heals the wound and makes the body stronger."

The Three R's of Phase 07

R	Name	What It Means
R1	REMEDIATION	Permanently fix the vulnerability or weakness that allowed the incident to happen. Patch systems, update
R2	RECOVERY	Restore all affected systems, services and data to full normal operation. Validate that everything is working
R3	RESILIENCE	Implement long-term improvements so the organisation is harder to attack and faster to recover if another

Where Phase 07 Sits in the Process Cycle

Phase	Activity	Relationship to Phase 07
Phase 01 — IT Systems Landscape	Documents all IT systems	Phase 07 feeds back here — updates system documentation after change
Phase 02 — Aggregation & Normalisation	Standardises log data	Phase 07 improves data collection based on what was missed during the
Phase 03 — SOC & SIEM	Detects threats	Phase 07 adds new detection rules to catch the same attack earlier next t
Phase 04 — Service Management	Tracks incidents via tickets	Phase 07 closes out tickets and updates SLAs based on lessons learned
Phase 05 — Workflow Automation	Automates response	Phase 07 adds new automated responses to playbooks
Phase 06 — Incident Response	Contains and eradicates the threat	Phase 07 begins where Phase 06 ends — permanent fix and recovery
Phase 07 — Remediation ★ PRIMARY	Remediates, recovers, builds resilience	Termination — feeds back to Phase 01 creating the continuous impro

NIST RECOVER Framework

Phase 07 maps to the NIST RECOVER function. NIST RECOVER defines the activities needed to restore capabilities and services impacted by a cybersecurity incident. It ensures the organisation returns to normal operation and improves its security posture based on lessons learned.

NIST Category	What It Means	Phase 07 Activity
Recovery Planning	Having documented recovery procedures	Ready before incidents: Plans for each system type, tested and validated
Improvements	Using incident findings to improve security	Root Cause Analysis, lessons learned, updated controls and policies
Communications	Keeping stakeholders informed during recovery	Status updates to management, customers, and regulators on recovery

Aims of Phase 07

Phase 07 aims to achieve "Remediation, Recovery, Resilience" through 8 actionable objectives:

1

Implement comprehensive recovery plans for all affected systems

Every system that was impacted must have a documented recovery procedure
Plans specify exactly how each system is restored — from backup, rebuild, or patch
Recovery is validated before the system is returned to production

2

Conduct thorough post-incident analysis to understand root causes (Root Cause Analysis)

Identify exactly what vulnerability or weakness was exploited
Trace the full attack chain from initial entry to final impact
Distinguish between root causes and contributing factors

3

Integrate lessons learned into existing security architecture

Findings from the incident are used to permanently improve the security design
New controls are added where gaps were identified
Architecture changes are documented and communicated

4

Update security policies and procedures based on incident findings

Policies that failed or were bypassed during the incident are revised
New procedures are written for scenarios that were not previously covered
Playbooks are updated with tactics that worked during the response

5

Enhance monitoring capabilities to detect similar threats earlier

New SIEM correlation rules added based on attack patterns observed
Additional log sources onboarded if gaps in visibility were identified
Threat intelligence feeds updated with new IOCs from the incident

6

Implement additional preventive controls to address identified vulnerabilities

Patch the specific vulnerability exploited in the incident
Implement compensating controls where patching is not immediately possible
Apply defence-in-depth — add multiple layers to prevent single points of failure

7

Test recovery procedures to ensure effectiveness

Run tabletop exercises and simulations using updated playbooks
Test backups by actually restoring from them — not just assuming they work
Measure recovery time and compare against RTO targets

8

Train staff on new security protocols established post-incident

Deliver awareness training based on the specific attack type that occurred

Update technical training for the IR and SOC teams

Security champions in each department reinforce the new protocols

Remediation — Permanent Fixes

Remediation is about permanently eliminating the weakness that allowed the incident to occur. Unlike containment (Phase 06) which is a temporary fix to stop immediate damage, remediation is the permanent solution.

Containment vs Remediation — Key Distinction

	Containment (Phase 06)	Remediation (Phase 07)
When	During the incident — immediately	After the incident is resolved
Goal	Stop the damage right now	Permanently fix the root cause
Example	Block the attacker's IP at the firewall	Patch the vulnerability the attacker exploited
Duration	Temporary — until proper fix is implemented	Permanent — closes the vulnerability for good
Risk	May disrupt normal operations	Thoroughly tested before deployment

Root Cause Analysis (RCA)

Root Cause Analysis is the structured process of identifying the fundamental reason an incident occurred. Without RCA, organisations fix the symptom rather than the cause — and the same incident recurs.

The 5 Whys Technique

The 5 Whys is a simple but powerful RCA technique. You keep asking "why?" until you reach the root cause rather than a symptom.

Question	Answer
Why did the attacker get in?	They exploited a vulnerability in the authentication system
Why did the vulnerability exist?	The authentication library had not been patched in 8 months
Why had it not been patched?	There was no patch management process for third-party libraries
Why was there no patch management process?	Security responsibility for third-party components was unclear
Why was responsibility unclear? (Root Cause)	No formal vendor security assessment program or ownership policy existed
ROOT CAUSE	Absence of a formal third-party security management program

Notice: The first answer ("they exploited a vulnerability") is not the root cause — it's a symptom. The actual root cause is an organisational process failure. This is what RCA uncovers.

Types of Remediation Actions

Type	Description	Examples
Technical Remediation	Direct technical fixes to systems and software	Patching vulnerabilities, updating configurations, replacing compromised components
Process Remediation	Fixing broken or missing operational processes	Implementing patch management, creating vendor assessment programs, updating incident response plans
People Remediation	Addressing human factors that contributed to the incident	Security awareness training, role reassignment, updated access control policies
Architectural Remediation	Structural changes to the security architecture	Network segmentation, zero-trust implementation, additional authentication layers

Recovery — Restoring to Full Operation

Recovery is the structured process of bringing all affected systems and services back to normal operation. It must be done carefully — rushing recovery can reintroduce vulnerabilities or miss compromised components.

Recovery Steps

1

Prioritise Systems for Recovery
Identify which systems are most critical to business operations
Use Business Impact Analysis (BIA) to determine recovery order
Critical systems (payment processing, authentication) recovered first
Less critical systems follow once core operations are restored

2

Validate Backups Before Restoring
Confirm backup integrity — verify hashes against known-good values
Test restore in an isolated environment before applying to production
Check backup date — ensure it predates the compromise
Never restore from a backup that may itself be compromised

3

Restore from Clean State
Rebuild systems from verified clean baselines or trusted backups
Apply all patches and security configurations during rebuild
Do NOT restore directly from a potentially compromised snapshot
Verify no malicious files, accounts, or configurations are reintroduced

4

Validate Restored Systems
Run vulnerability scans on all restored systems
Verify file integrity against known-good hashes
Confirm all services and applications are functioning correctly
Check that monitoring and logging are working on restored systems

5

Gradually Return to Normal Operations
Do not rush full restoration — monitor closely for signs of reinfection
Restore services incrementally — start with low-risk systems
Keep enhanced monitoring in place for at least 30 days post-recovery
Confirm with business stakeholders that operations are fully normal

6

Update Documentation
Record all changes made during recovery in the CMDB
Update system diagrams and IT landscape documentation (Phase 01)
Document new configurations applied during the rebuild
Close out the incident ticket in Phase 04 service management system

Recovery Time Objectives

Term	Definition	Example
RTO — Recovery Time Objective	The maximum acceptable time a system can be offline before the business is seriously impacted	Payoffline system RTO is 1 hour. After 1 hour impacted
RPO — Recovery Point Objective	The maximum acceptable amount of data loss	RPO is 4 hours. How much data can be restored back up to 3 of data

MTTR — Mean Time to Recover	The actual average time it takes to restore a system after a disaster.	If MTTR > RTO, recovery time is too long.	Need to improve backup p
-----------------------------	--	---	--------------------------

Knowledge Check: What is the difference between RTO and RPO?

✓ **Answer:** RTO is about TIME — how long can a system be down? RPO is about DATA — how much data can we afford to lose? An RTO of 2 hours means the system must be back online within 2 hours. An RPO of 1 hour means backups must run every hour so we never lose more than 1 hour of data.

Resilience Building — Long-Term Improvements

Resilience is the most forward-looking part of Phase 07. It is about making the organisation fundamentally more difficult to attack and faster to recover from future incidents. Resilience building ensures that Phase 07 is not just a recovery exercise but a genuine opportunity for organisational improvement.

Key Resilience Measures

- **Security Architecture Improvements:**
 - Network segmentation — isolate sensitive systems from general infrastructure
 - Zero-trust architecture — never trust, always verify, regardless of network location
 - Defence in depth — multiple security layers so one failure does not lead to a breach
 - Least privilege access — users and systems only have the access they genuinely need
- **Detection Improvements:**
 - Add new SIEM correlation rules based on attack patterns from the incident
 - Onboard additional log sources that had blind spots during the incident
 - Update threat intelligence feeds with new IOCs discovered during investigation
 - Implement user behaviour analytics (UBA) if insider threat or compromised credentials were involved
- **Process Improvements:**
 - Update IR playbooks with lessons from the incident
 - Implement or improve patch management processes
 - Establish formal vendor/third-party security assessment programs
 - Create a security champions program within each business unit
- **Testing and Validation:**
 - Regular penetration testing — actively try to break in before attackers do
 - Red team exercises — simulate full attack scenarios
 - Tabletop exercises — walk through IR scenarios with the team
 - Disaster recovery drills — actually restore from backups to prove they work
- **People and Culture:**
 - Security awareness training tailored to the specific attack type that occurred
 - Bug bounty programs — incentivise external researchers to find vulnerabilities
 - Clear security responsibilities — everyone knows their role
 - No-blame post-incident culture — encourages honest reporting and learning

The Feedback Loop — Phase 07 Back to Phase 01

The most important concept in Phase 07 is that it does not end the process cycle — it feeds back into the beginning. Every improvement made in Phase 07 makes every earlier phase more effective. This is what makes cyber security a continuous improvement cycle rather than a one-time project.

Phase Updated	What Phase 07 Feeds Back	Outcome
Phase 01 — IT Systems	Updated system documentation after changes made during recovery	Accurate inventory landscape reflects new configurations and changes
Phase 02 — Aggregation	New log sources onboarded, improved data collection	Fewer blind spots in the data pipeline, better quality intelligence
Phase 03 — SOC & SIEM	New correlation rules, updated threat intelligence, new IOCs	Earlier detection of the same attack pattern in future
Phase 04 — Service Management	Updated SLAs and response procedures, closed incident tickets	Improved response times and clearer team responsibilities
Phase 05 — Workflow Automation	New playbooks automated, additional response actions implemented	Faster automated response to similar incidents

Key Point: Phase 07 completing the loop back to Phase 01 is what makes cyber security an ongoing process rather than a series of isolated reactions. Each incident makes the entire cycle more effective — this is the core principle behind continuous improvement in security operations.

Case Study — GameForge Studios

Organisation: GameForge Studios — mid-sized game development company. Creates multiplayer online games with millions of active users. Maintains sensitive intellectual property, player account information, and payment processing systems.

The Incident: Threat actors exploited a vulnerability in GameForge's third-party authentication system. Attackers gained access to development servers containing unreleased game code and potentially compromised player account information. Breach was detected when unusual database queries were flagged by their monitoring system.

Phase 07 Implementation — What GameForge Did

After Phase 06 contained the breach and removed attacker access, GameForge implemented a structured 5-part Phase 07 recovery strategy:

• 1. Immediate Restoration Activities

- Rebuilt compromised development servers from clean baselines
- Restored code repositories from secure backups after integrity verification
- Implemented emergency patches to the authentication system
- Reset credentials for all internal systems and developer accounts

• 2. Comprehensive Recovery Measures

- Conducted forensic analysis to identify the complete attack chain
- Verified integrity of all game code to ensure no malicious modifications remained
- Implemented additional authentication layers for developer access
- Enhanced network segmentation between development, testing, and production environments

• 3. Long-Term Resilience Building

- Established a dedicated security team focused on gaming-specific threats
- Implemented a formal third-party security assessment program for all vendor integrations
- Developed an enhanced security development lifecycle for game code
- Created an early warning system to detect potential compromises of player accounts
- Established regular penetration testing of both infrastructure and game client security

• 4. Organisational Improvements

- Updated incident response playbooks based on lessons learned
- Implemented security awareness training focused on game development risks
- Established a bug bounty program to incentivise security researchers
- Created a security champions program within development teams

• 5. Feedback into Process Cycle

- Updated IT systems landscape documentation (Phase 01)
- Enhanced data aggregation and normalisation capabilities (Phase 02)
- Expanded SOC monitoring to include game-specific threat intelligence (Phase 03)
- Improved service management integration with automated security tickets (Phase 04)
- Automated additional security workflows based on incident learnings (Phase 05)

Results: Six months after implementing Phase 07, GameForge had significantly improved their security posture. They successfully prevented several attempted attacks using similar techniques. Improved monitoring detected potential issues much earlier. Security improvements were integrated into their marketing as a competitive advantage — assuring players their accounts and data were well-protected. This demonstrates how Phase 07 serves not only as a recovery mechanism but as a catalyst for organisational transformation.

Code Concepts — Phase 07 Automation

Phase 07 automation focuses on three areas: automating verification of recovery, tracking remediation actions, and feeding improvements back into the security pipeline.

1. Automated Patch Verification — Confirming Remediation is Complete

```
def verify_remediation(incident_id, affected_systems):
    """Check all systems have been patched and verified post-incident"""
    results = []

    for system in affected_systems:
        checks = {
            "system": system["hostname"],
            "patch_applied": check_patch_status(system, incident_id),
            "vuln_scan_clean": run_vulnerability_scan(system),
            "integrity_verified": verify_file_integrity(system),
            "monitoring_active": check_monitoring_status(system)
        }
        # System is fully remediated only if ALL checks pass
        checks["remediation_complete"] = all([
            checks["patch_applied"],
            checks["vuln_scan_clean"],
            checks["integrity_verified"],
            checks["monitoring_active"]
        ])
        results.append(checks)

    total = len(results)
    complete = sum(1 for r in results if r["remediation_complete"])
    print(f"Remediation: {complete}/{total} systems verified complete")
    return results
```

2. Recovery Validation — Checking Systems Are Clean Before Restoration

```
import hashlib

def validate_backup_integrity(backup_path, known_good_hash):
    """Verify backup has not been tampered with before restoring"""
    sha256 = hashlib.sha256()
    with open(backup_path, "rb") as f:
        for chunk in iter(lambda: f.read(8192), b''):
            sha256.update(chunk)
    actual_hash = sha256.hexdigest()

    if actual_hash == known_good_hash:
        print(f"✓ Backup integrity verified: {backup_path}")
        return True
    else:
```

```
print(f"X INTEGRITY FAILURE: {backup_path}")
print(f" Expected: {known_good_hash}")
print(f" Got: {actual_hash}")
return False # DO NOT RESTORE – backup may be compromised
```

3. Lessons Learned Report Generator — Feeding Back into the Cycle

```
from datetime import datetime

def generate_lessons_learned(incident_id, timeline, root_causes, actions_taken):
    """Auto-generate lessons learned report for Phase 07 closure"""
    report = {
        "incident_id": incident_id,
        "report_date": datetime.now().isoformat(),
        "executive_summary": summarise_incident(timeline),

        # What happened
        "root_causes": root_causes,
        "attack_timeline": timeline,

        # What we did
        "containment_actions": actions_taken["containment"],
        "eradication_actions": actions_taken["eradication"],
        "recovery_actions": actions_taken["recovery"],

        # What we are improving
        "siem_rule_updates": actions_taken["new_detection_rules"],
        "playbook_updates": actions_taken["playbook_changes"],
        "policy_updates": actions_taken["policy_changes"],
        "architecture_changes": actions_taken["architecture_improvements"],

        # Metrics
        "mttd_minutes": calculate_mttd(timeline),
        "mttc_minutes": calculate_mttc(timeline),
        "mttr_minutes": calculate_mttr(timeline),
    }
    return report
```

Code Breakdown: These three functions represent the automation backbone of Phase 07. The first ensures every system is verified before the incident is closed. The second prevents restoring from a compromised backup — a critical safety check. The third automatically generates the lessons learned document and feeds improvements back into SIEM rules, playbooks, and policies — completing the cycle.

How Phase 07 Maps to Your Project Tools

Project	How Phase 07 Concepts Apply
Data Engineering (ELK)	Kibana dashboards track recovery progress. New index patterns added for better visibility. Detection rules
Security Monitoring (Graylog)	New alert streams created from lessons learned. Improved extraction rules for log sources that had gaps. U

Security Monitoring (Security Onion)	Snurca rules updated with new signatures from the attack. Zeek scripts improved to detect lateral movement.
Incident Response (TheHive)	Case closed with full lessons learned documentation. New case templates created for the incident type. MITRE ATT&CK framework integrated.
Security Assessment (Wazuh)	File integrity monitoring rules updated. Active response rules improved based on what worked during containment.
Systems Maintenance (Ansible)	New remediation playbooks created for the specific vulnerability exploited. Patching automation updated to include new patches.

Knowledge Checks

Knowledge Check: What are the three R's of Phase 07 and what does each mean?

✓ **Answer:** Remediation — permanently fix the root cause vulnerability. Recovery — restore all affected systems to full normal operation. Resilience — implement long-term improvements so the organisation is harder to attack and faster to recover in future.

Knowledge Check: What is the difference between Phase 06 and Phase 07?

✓ **Answer:** Phase 06 is about stopping the immediate threat — containing it, eradicating it, and getting systems back online as quickly as possible. Phase 07 comes after and focuses on permanently fixing what caused it, fully restoring everything, and making the organisation stronger so it does not happen again.

Knowledge Check: What is Root Cause Analysis and why is it important?

✓ **Answer:** RCA is the structured process of identifying the fundamental reason an incident occurred. It is important because without it, organisations fix the symptom rather than the cause — patching the system but not fixing the process that allowed it to go unpatched for 8 months. The same incident will recur without addressing the root cause.

Knowledge Check: Why does Phase 07 create a feedback loop back to Phase 01?

✓ **Answer:** Because cyber security is a continuous improvement cycle, not a linear process. Every incident reveals gaps across all phases. Phase 07 feeds improvements back into every earlier phase — better log collection (Phase 02), new detection rules (Phase 03), updated playbooks (Phase 05) — making the entire cycle more effective each time.

Knowledge Check: What is the difference between RTO and RPO?

✓ **Answer:** RTO (Recovery Time Objective) is the maximum acceptable time a system can be offline. RPO (Recovery Point Objective) is the maximum acceptable data loss measured in time. RTO drives how fast you must restore. RPO drives how frequently you must back up.

Knowledge Check: Why must you validate backups before restoring them during recovery?

✓ **Answer:** Backups themselves may be compromised if the attacker had access to backup systems, or they may predate the compromise but contain the vulnerability that was exploited. Restoring a compromised backup reintroduces the attacker into the environment. Always verify the backup hash and confirm the backup predates the incident.

Phase 07 — Full Terminology Glossary

Term	Definition
Phase 07 — Remediation, Recovery, Resilience	The final phase of the Cyber Security Operations Process Cycle. Focuses on permanently fixing the root cause, restoring full operations, and building long-term resilience. Maps to NIST RECOVER.
NIST RECOVER	The NIST Cybersecurity Framework function covering activities to restore capabilities and services impacted by a cybersecurity incident and to maintain plans for resilience.
Remediation	The permanent elimination of the vulnerability or weakness that allowed an incident to occur. Distinct from containment which is temporary.
Recovery	The process of restoring affected systems, services, and data to full normal operation after an incident has been resolved.
Resilience	The ability of an organisation to anticipate, withstand, recover from, and adapt to security incidents. Built through improvements made after each incident.
Root Cause Analysis (RCA)	A structured method for identifying the fundamental underlying reason an incident occurred, rather than just addressing its symptoms. The 5 Whys is a common RCA technique.
The 5 Whys	An RCA technique where you ask "why?" repeatedly (typically 5 times) until you reach the root cause rather than stopping at a symptom.
Post-Incident Review	A structured review of the entire incident conducted after resolution. Produces lessons learned, identifies root causes, and generates recommendations for improvement.
Lessons Learned	The documented findings from a post-incident review, including what went well, what failed, root causes, and specific actions to prevent recurrence.
RTO — Recovery Time Objective	The maximum acceptable duration of time a system can be offline after a disruption before the business impact becomes unacceptable.
RPO — Recovery Point Objective	The maximum acceptable amount of data loss measured in time. Determines how frequently backups must be taken.
Business Impact Analysis (BIA)	An assessment of the potential business effects of system disruptions. Used to prioritise which systems must be recovered first.
Patch Management	The systematic process of identifying, acquiring, testing, and installing software patches to address vulnerabilities. A missing patch management process is a common root cause finding.
Vulnerability Management	The ongoing process of identifying, classifying, prioritising, and remediating security vulnerabilities across the organisation's systems.
Defence in Depth	A security strategy that employs multiple layers of controls so that if one layer fails, others still protect the organisation. No single point of failure.
Zero Trust	A security model based on the principle of "never trust, always verify." No user or system is trusted by default, regardless of whether they are inside or outside the network.
Network Segmentation	Dividing a network into isolated segments so that a compromise in one segment cannot easily spread to others. A key resilience measure.
Least Privilege	The principle that users and systems should only have the minimum access required to perform their legitimate functions. Limits attacker movement if credentials are compromised.

Penetration Testing	Authorised simulated attack on a system or network to identify vulnerabilities before real attackers do. A key resilience testing activity.
Red Team Exercise	A full attack simulation where a dedicated team (the red team) attempts to compromise the organisation using real attacker techniques. Tests the entire security programme.
Tabletop Exercise	A discussion-based simulation where the IR team talks through their response to a hypothetical incident scenario. Tests readiness without actual system involvement.
Bug Bounty Programme	A programme that rewards external security researchers for responsibly disclosing vulnerabilities they find. Extends the organisation's testing capability cost-effectively.
Security Champions Programme	Designating security-aware individuals within each business or development team to promote security practices and act as a bridge to the dedicated security team.
Third-Party Risk Management	The process of identifying and managing security risks introduced by vendors, suppliers, and partners who have access to systems or data. Third-party weaknesses are a common attack vector (as in the GameForge case study).
CMDB — Configuration Management Database	Repository of IT infrastructure information and relationships, updated during Phase 07 to reflect all changes made during recovery.
Continuous Improvement	The principle that security is never "finished" — each incident, test, and review generates findings that improve the programme. Phase 07 completing the loop back to Phase 01 embodies this principle.
Forensic Baseline	A known-good snapshot of a system's state used to compare against a potentially compromised system. Created during normal operations as part of preparation.
Integrity Verification	The process of confirming that files, systems, or backups have not been modified by comparing cryptographic hashes against known-good values.
Attack Surface Reduction	Minimising the number of ways an attacker can enter or interact with systems. Achieved by disabling unnecessary services, closing ports, and removing unused software.
Security Development Lifecycle (SDL)	A process for building security into software development from the start, rather than adding it afterwards. Includes security requirements, design reviews, and code scanning.

Phase 07 — Quick Reference Card

Concept	Key Point
Three R's	Remediation → Recovery → Resilience
NIST Mapping	NIST RECOVER
Phase 07 begins when	Phase 06 has contained and eradicated the threat
Remediation vs Containment	Containment = temporary stop. Remediation = permanent fix.
Root Cause Analysis	Use 5 Whys to find the true root cause, not just symptoms
RTO	Recovery Time Objective — max acceptable downtime
RPO	Recovery Point Objective — max acceptable data loss (drives backup frequency)
Before restoring backup	Always verify hash. Confirm backup predates the compromise.
Resilience measures	Network segmentation, zero trust, pen testing, defence in depth
Feedback loop	Phase 07 feeds improvements back to ALL earlier phases

The cycle	Phase 07 → Phase 01 → continuous improvement loop
GameForge lesson	Third-party vulnerabilities require formal vendor security assessment programmes
Key tool	TheHive closes the case. Ansible automates remediation. MISP updated with new IOCs.
NIST RECOVER categories	Recovery Planning · Improvements · Communications

PHASE 07 · Lab Notes

Week 7 Lab: Post-Incident Response and Remediation

Remediate · Recover · Rebuild · Prevent Recurrence

Overview

This lab focuses on **Phase 07** of the Cyber Security Operations Process Cycle. In Week 6, you conducted a threat hunt and discovered a multi-stage cyber attack. This week, you will complete the incident response cycle by documenting the remediation, recovery, and resilience measures needed to address the incident.

Week 6 activity is still available for you to practise.

Summary

Remediation, Recovery, and Resilience: analyse an incident, fix it, recover from it, prevent it happening again, and document the whole process.

Part 1 Root Cause Analysis

Objective: Understand why the attack succeeded.

Step 1 — Review Your Week 6 Findings

- Review the three challenge datasets:
- **challenge1_initial_compromise.csv**
- **challenge2_lateral_movement.csv**
- **challenge3_data_exfiltration.csv**

Step 2 — Build the Attack Timeline

- In **Section 2** of the template, document each stage of the attack
- Include timestamps from the CSV files
- Note the progression: Phishing → Credential Theft → Lateral Movement → Data Exfiltration

Step 3 — Identify Root Causes

- In **Section 3**, answer these questions:
- What vulnerability allowed the initial compromise?
- What weakness enabled lateral movement?
- What gap allowed data exfiltration?
- Consider: Missing controls, misconfigurations, lack of monitoring

Step 4 — List Affected Systems

- In **Section 4**, document all compromised systems from your CTF analysis
- Note what data was accessed or stolen

Part 2 Remediation Planning

Objective: Document immediate actions to stop and remove the threat.

Tasks

- **Containment Actions (Section 5.1)** — List steps to isolate affected systems; identify IPs/domains to block (from CTF findings); document evidence preservation steps
- **Eradication Actions (Section 5.2)** — List all credentials that need resetting: compromised user account [from Challenge 1], privileged account used [from Challenge 2]; identify systems requiring cleanup; list patches/updates needed
- **Think Through the Sequence** — What must be done first? (Containment) · What's next? (Eradication) · What can wait? (Some hardening measures)

Part 3 Recovery Procedures

Objective: Plan how to restore normal operations safely.

Tasks

- **System Restoration (Section 6.1)** — For each compromised system outline: how to verify backups; steps to rebuild/restore; how to verify the system is clean; prioritise critical systems first
- **Service Restoration (Section 6.2)** — Identify affected services; set priorities (P1 = Critical, P2 = Important, P3 = Normal); estimate recovery time for each
- **Communication Plan (Section 6.3)** — Who needs to know about this incident? What should they be told? When should they be notified?

Part 4 Resilience Measures

Objective: Prevent this type of attack in the future.

Detection Rules (Section 7.1)

Write **5 detection rules** based on your CTF findings, using the template format provided. Cover each stage of the attack:

Rule	Detect
Rule 1	Detect credential phishing
Rule 2	Detect lateral movement
Rule 3	Detect data exfiltration
Rule 4	Your choice based on findings
Rule 5	Your choice based on findings

Preventive Controls (Section 7.2)

Tasks

- **Technical controls** — MFA, network segmentation, DLP, endpoint protection, patch management
- **Process controls** — Security awareness training, access reviews, change management
- **Monitoring enhancements** — Additional log sources, improved detection thresholds, threat intelligence feeds

Policy Updates (Section 7.3)

Tasks

- What policies need updating?
- What new procedures are needed?

Lessons Learned (Section 8)

Tasks

- What worked well in detection?
- What could be improved?
- What training is needed?

Part 5 Project Integration

Objective: Connect this incident response to your group project.

Consider how **your project tool** addresses each of the following integration points:

Incident Detection	How would your tool detect this incident?
Case/Alert Management	How would your tool track remediation progress?
Automated Response	What could be automated in your tool?
Reporting	How would your tool generate reports like this?
Preventive Measures	How would you implement the resilience measures in your tool?
Your Project Tool	TheHive · ELK · Graylog · Security Onion · Wazuh · OpenVAS · Ansible

■ Share your findings with your group or on the **Knowledge Share** link.